

SC EXAM PREP — PREDICTED 2026

暗号・認証・PKI

PKCE／パスキー(FIDO2/WebAuthn)／OIDC／OCSP／mTLS／耐量子暗号(PQC)。認証・認可・鍵基盤の頻出論点を、代表5問で「経路」と「役割」から体系学習する。

Q1・RFC 7636

PKCE と認可コード横取り
対策

頻出 ★★★

Q2・WebAuthn

パスキーのフィッシング耐
性

頻出 ★★★

Q3・OIDC

ID トークン(JWT)の検証

頻出 ★★★

Q4・OCSP

OCSP ステージング

頻出 ★★★

Q5・RFC 8705

mTLS と証明書バインドト
ークン

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「フロント認証 → 認可コード → 認証連携 → 失効確認 → サーバ間信頼」の動線

Q1

PKCE

公開クライアントの認可コード横取りを防ぎ、正規主体だけがトークン交換できる

RFC 7636 / OAuth 2.0



Q2

パスキー

オリジンを署名対象にバインドしRPが検証。偽ドメインで署名検証不成立

FIDO2 / WebAuthn



Q3

OIDC

IDトークン(JWT)で「誰が認証されたか」を伝達。
iss/aud/exp/nonce検証

OIDC / 認証と認可



Q4

OCSP

証明書の失効確認。ステープリングでプライバシー・可用性を改善

RFC 6960 / PKI



Q5

mTLS

相互TLS + 証明書バインドトークンで盗難トークンの再利用を阻止

RFC 8705 / ゼロトラスト

STEP 1 | WHY

「認証(誰か)・認可(何を許可)・PKI(鍵/証明書)」の3層で全体像を掴む

STEP 2 | HOW

5問で「どの層・どのRFCの話か」を判別し、混同狙いの選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(オリジン束縛・鍵所有証明・完全一致・失効確認)へ落とす

① 基礎概念 — 認証・認可・PKI 全体マップ

「通信の主体(層)」×「認証/認可/鍵基盤」の2軸で本デッキ5問を配置

CONCEPT

通信の主体 / 層	認証 (誰か)	認可・トークン (何を許可)	証明書・鍵基盤 (PKI / 暗号)
利用者 ⇄ Webサイト (RP)	Q2 パスキー(FIDO2/WebAuthn)/ジェイルブレイク不可のオリジン束縛	Q1 認可コードフロー + PKCE(RFC 7636)	TLSサーバ証明書
認証連携 IdP ⇄ RP	Q3 OIDC IDトークン(JWT)/認証層	OAuthアクセストークン(RFC 6749/6750, Bearer)	JWT署名 / JWKS(kid で公開鍵取得)
サーバ ⇄ サーバ / 基盤	Q5 mTLS(相互TLS)でクライアント認証	証明書バインドトークン(RFC 8705)/DPoP(RFC 9449)	Q4 失効確認 OCSP/CRL・PQC 移行

核心: 論点は「①どの層の通信か(フロント/認証連携/サーバ間)」と「②何の話か(認証=誰か/認可=何を許可/PKI=鍵・証明書)」で切り分けられる。認証(OIDC IDトークン)と認可(OAuthアクセストークン)の混同、および失効確認方式(OCSP/CRL/ステープリング)の取り違えが4択の定番ひっかけ。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「役割・経路・対策」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
トークンの役割	OIDC IDトークン = 認証「誰が認証されたか」をRPへ伝達	OAuthアクセストークン = 認可「何にアクセス可か」。認証as認可の混同
失効確認方式	OCSPステープリング = サーバが署名済み応答をTLSに添付し提示	従来OCSP = クライアントがレスポンスへ直接問合せ、アクセス先が漏れる
トークン束縛	送信者制約トークン = 鍵所有の証明にバインド(cert-bound/DPoP)	ベアラトークン = 所持者なら誰でも利用可、盗難再利用に弱い
パスキー種別	device-bound passkey = 鍵が認証器内に留まり攻撃面が狭い	synced passkey = クラウド同期でアカウント乗っ取り時に一括危険化
redirect_uri登録	完全一致(exact)登録 = コード送信先を厳格に固定	前方一致(部分一致) = コード横取り/オープンリダイレクト悪用

PKCE Proof Key for Code Exchange

認可要求ごとに code_verifier(乱数)とハッシュ code_challenge(S256)を用い、認可コード横取り者の交換を阻止(検知でなく交換のbinding)。

 **RFC 7636 / OAuth 2.0**

OIDC IDトークン OpenID Connect

OAuth上の認証層。JWTで署名されたJWTで「誰が認証されたか」を伝達。iss/aud/exp、要求時はnonceを検証して初めて信頼可。

 **OIDC Core / JWT(RFC 7519)**

証明書バインドトークン certificate-bound

アクセストークンをmTLSクライアント証明書のサムプリント(cnfのx5t#S256)に束縛。秘密鍵なしでは盗難トークンを再利用できない。

 **RFC 8705**

JWKS / kid JSON Web Key Set

署名検証用の公開鍵集合。JWTヘッダのkidで対応鍵を選択。複数鍵の並行公開で無停止の鍵ローテーションが可能。

 **RFC 7517**

FIDO2 / WebAuthn パスキー

clientDataにオリジン、authenticatorDataにrpIdHashを含めて認証器が署名。RPがオリジン一致を検証し偽サイトでは不成立=フィッシング耐性。

 **W3C WebAuthn / CTAP**

OCSPステープリング OCSP Stapling

サーバがCA(レスポнда)から取得した署名済みOCSP応答をTLSハンドシェイクに添付。署名者は常にCA。プライバシー・可用性を改善。

 **RFC 6960 / RFC 6066**

DPoP Demonstrating PoP

クライアント保有鍵で署名したDPoP証明をリクエストに付与し、トークンを鍵所有に束縛する送信者制約方式。ベアラ盗難再利用を防ぐ。

 **RFC 9449**

耐量子暗号(PQC) Post-Quantum

ショアのアルゴリズムでRSA/ECCが危殆化。格子ベース(ML-KEM等)へ移行。計算量的仮定に依存し情報理論的安全ではない。

 **FIPS 203 / CRYPTREC**

「認証／認可／トークン束縛／失効／PQC」の根拠を取り違えない

規格 / RFC	種別	要点 (試験での問われ方)
RFC 7636 PKCE	認可コード保護	code_verifier/challenge(S256)でコード横取りを阻止。 Q1の正解 。公開クライアント向け。
RFC 6749 / 6750 OAuth 2.0	認可フレームワーク	認可コード・アクセストークン(Bearer)。あくまで 認可 であり 認証 ではない。
OpenID Connect Core	認証層	OAuth上のIDトークン(JWT)で 認証 。iss/aud/exp/nonce検証。 Q3の正解 。
W3C WebAuthn / FIDO2	パスワードレス認証	オリジンを署名対象に束縛しRPが検証=フィッシング耐性。 Q2の正解 。
RFC 8705 (mTLS) / RFC 9449 (DPoP)	送信者制約トークン	cnf(x5t#S256)/鍵所有証明でトークンを束縛。 Q5 ・午後の狙い目。
RFC 6960 OCSP / RFC 5280 CRL	証明書失効	OCSP=個別問合せ、CRL=一覧DL、ステープリング=TLS添付。 Q4 。
FIPS 203 ML-KEM / CRYPTREC	耐量子暗号(PQC)	ショアでRSA/ECC危殆化→格子ベース移行。移行期はハイブリッド鍵交換が推奨。

 **頻出の軸:** 「認証=OIDC/WebAuthn」「認可=OAuth」「トークン束縛=RFC 8705/9449」「失効=OCSP/CRL」「PQC=FIPS 203」。RFC番号と“何の話か”をセットで暗記すると4択のひっかけを外さない。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. 認証か認可かで峻別: IDトークン(誰か)=OIDC/認証、アクセストークン(何を許可)=OAuth/認可。
2. フィッシング耐性の本質は「**オリジンを署名にバインドしRPが検証**」。OTPやパスワードハッシュは本質でない。
3. トークン盗難対策は「**鍵所有の証明に束縛(cert-bound/DPoP/mTLS)**」=送信者制約トークン。
4. PKCEは"検知"でなく"**交換の阻止(binding)**"。redirect_uriは**完全一致**登録。

⚠ よくあるひっかけ

- パスキーを「**秘密鍵が漏れない**」だけで説明→それは鍵漏えい耐性で別論点、減点。
- OCSPステープリングの利点と従来OCSPの課題を取り違える。**署名者は常にCA**(Webサーバでない)。
- 「クッキー暗号化」「有効期限短縮」だけではトークン窃取再利用を緩和しきれない(束縛が主眼)。
- PQCは**情報理論的安全ではない**。AES-256はGroverでも実用上安全。ハイブリッド鍵交換は**推奨**(避けるは誤)。

合言葉: 「層(どこ)×役割(認証/認可/PKI)」で分類 → 対策は「**オリジン束縛・鍵所有証明・完全一致・失効確認・ハイブリッド移行**」の5語彙に集約される。

OAuth 2.0 の認可コードフローに PKCE(Proof Key for Code Exchange)を適用する主目的として、最も適切なものはどれか。

ア アクセストークンを JWT 形式にし、リソースサーバでの署名検証を可能にする

イ 認可サーバとリソースサーバ間の通信を相互 TLS で保護する

ウ 悪意のあるアプリによる認可コードの横取りを防ぎ、正規クライアント(元の認可要求を出した主体)だけがトークンと交換できるようにする

エ リフレッシュトークンの有効期限を延長し、再認可の頻度を下げる

正解 ウ ア=JWTアクセストークンの話/イ=mTLSの話/エ=PKCEの目的ではない

空 (事実)

ネイティブ/SPAなど公開クライアントでは、認可コードを横取り(Authorization Code Interception)され得る。

雨 (解釈)

要求ごとにcode_verifier(高エントロピー乱数)を生成しcode_challenge(S256)を送付、交換時にverifierを提示して束縛。本質は「検知」でなく交換の阻止。

傘 (対策)

PKCE適用で、コードを横取りした第三者はcode_verifierを知らずトークン交換できない。

FIDO2/WebAuthn によるパスキー認証がフィッシングに耐性をもつ根本的な理由として、最も適切なものはどれか。

ア 認証のたびにワンタイムパスワードを生成し、一定時間で失効させるため

イ 署名対象データにアクセス先のオリジン情報がバインドされ、RP がオリジンの一致を検証するため、偽ドメインでは署名検証が成立しない

ウ 秘密鍵をサーバ側にも複製保管し、突合により本人性を確認するため

エ 利用者が入力したパスワードをソルト付きハッシュで保存するため

正解 イ ア=OTPはAiTM中継で突破され得る/ウ=秘密鍵は認証器内に留まる(誤)/エ=本質でない

空 (事実)

clientDataに乱数チャレンジとオリジン、authenticatorDataにrpIdHashが含まれ、認証器がそのハッシュに署名する。

雨 (解釈)

RPは署名検証時にオリジン/rpIdHashの一致を検証。オリジンの異なる偽サイトでは検証に失敗し、資格情報もrpIdのオリジンでしか呼ばれない。

傘 (対策)

パスワードレス+オリジン束縛のパスキーへ移行。秘密鍵はサーバへ渡らず認証器内に留まる。

実務メモ: AiTM(中間者型)フィッシングではOTPも中継突破される。「秘密鍵が漏れない」だけでは説明不足で、オリジンを署名にバインドしRPが検証と書けるかが分水嶺。

OpenID Connect(OIDC)における ID トークンに関する記述のうち、適切なものはどれか。

ア ID トークンは JWS で署名された JWT であり、iss・aud・exp・(要求時は)nonce 等のクレームを検証して初めて認証結果として信頼できる

イ ID トークンは認可(アクセス権の委譲)そのものを表し、リソースアクセスに直接使用する

ウ ID トークンの署名検証には、クライアントとサーバで事前共有した対称鍵のみを用いる

エ ID トークンは平文の JSON であり、TLS 上で送るため署名は不要である

正解 ア イ=アクセストークンの役割(認証/認可の混同)/ウ=非対称鍵(RS256等)が一般/エ=改ざん検知に署名必須

▲ 空 (事実)

OIDCはOAuth 2.0上に構築した「認証」層で、IDトークン(JWT)により「誰が認証されたか」を伝える。

● 雨 (解釈)

受信側RPは署名(通常RS256、JWKSからkidで公開鍵取得)とiss/aud/expを必ず検証し、リプレイ防止に要求時はnonceも照合する。

✦ 傘 (対策)

検証項目の徹底を運用に組み込む。認証(IDトークン)と認可(アクセストークン)を混同しない。

電子証明書の失効確認方式である **OCSP** と、そのプライバシー・可用性上の課題を改善する **OCSP ステージング**に関する記述のうち、適切なものはどれか。

ア OCSP ステージングでは、クライアントが検証対象サーバごとに OCSP レスポンドへ直接問い合わせるため、利用者のアクセス先が漏れる

イ **OCSP ステージング**では、サーバがあらかじめ取得した有効期限付きの署名済み **OCSP レスポンス**を **TLS ハンドシェイク**時にクライアントへ提示する

ウ OCSP は CRL 全体をダウンロードして失効を確認する方式であり、証明書ごとの個別問い合わせはできない

エ OCSP ステージングを用いると、失効情報の署名者は当該 Web サーバ自身になる

正解 イ ア=従来OCSPの課題(ステージングでない)/ウ=CRLの説明/エ=署名者はCA(OCSPレスポンド)

▲ 空 (事実)

サーバがCA(OCSPレスポンド)から取得した署名済みレスポンスをTLSハンドシェイクに添付(staple)し、Certificate Statusとして提示する。

● 雨 (解釈)

クライアントがレスポンドへ直接問い合わせないため、アクセス先の漏えいを防ぎ、レスポンドの負荷・可用性依存も下げる。署名者はあくまでCA。

✦ 傘 (対策)

ステージング採用でプライバシーと可用性を両立。従来OCSP直問合せ/CRL一覧DLとの違いを整理。

サーバ間 API 通信で mTLS(相互 TLS)と、証明書にバインドしたアクセストークン(certificate-bound token, RFC 8705)を組み合わせる主目的として、最も適切なものはどれか。

ア トークンが漏えいしても、対応するクライアント証明書の秘密鍵を持たない第三者は当該トークンを使えないようにする

イ トークンのペイロードを暗号化し、リソースサーバ以外が内容を読めないようにする

ウ トークンの有効期限を無期限にし、再発行を不要にする

エ クライアントがパスワードを送信することで多要素認証を実現する

正解 ア イ・ウ・エはいずれも目的ではない

▲ 空 (事実)

アクセストークンを、mTLSで提示したクライアント証明書のサムプリント(確認方法クレーム cnf の x5t#S256)に束縛する。

☂ 雨 (解釈)

リソースサーバは提示時のmTLS証明書のハッシュとcnfを照合。盗まれても正規証明書の秘密鍵がなければ利用できず、ベアラ盗難再利用(リプレイ)を防ぐ。

☂ 傘 (対策)

ゼロトラストのサービス間通信で、送信者制約トークン(cert-bound / DPoP)を採用してトークン窃取の被害を封じる。



午後 記述式 — シナリオ要点

パスワードレス認証導入/外部API連携の OAuth・PKI 運用

記述

◆ 問1 (春想定) 社内SaaSパスワードレス認証

- 設問1: AiTMでパスワード+SMS OTP突破・クッキー窃取 → パスキー移行。オリジンを署名対象にバインドしRPが検証するため偽ドメインで署名検証不成立。
- 設問2: セッション乗っ取り残存 → 送信者制約トークン(RFC 8705 cert-bound / RFC 9449 DPoP / DBSC)で鍵所有証明に束縛し窃取再利用を防止。
- 設問3: synced passkeyは同期クラウドアカウントが防御境界となり、乗っ取り時に複数デバイスが一括危殆化。

◆ 問2 (秋想定) 外部API連携 OAuth + PKI

- 設問1: JWT検証は署名 + **aud**(未検証=トークン転用/混同) + **exp**(未検証=失効/期限切れ受理継続)。iss/nbfでも可。
- 設問2: JWKSに**kid**付き複数鍵を並行公開、新旧のオーバーラップ期間+キャッシュTTL考慮で無停止ローテーション。
- 設問3: redirect_uri前方一致 → 認可コード横取り/オープンリダイレクト悪用。是正策は**完全一致(exact)**登録。

採点の分水嶺: ①フィッシング耐性は「**オリジン署名バインド + RP検証**」(鍵漏えい耐性と区別) ②残存対策は「**鍵所有証明への束縛(送信者制約)**」 ③JWTは**aud/exp**まで検証 ④redirect_uriは**完全一致**・鍵は**kid**で**無停止ローテーション**まで踏み込めているか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度で暗号・認証・PKI論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
PKCE / 認可コード保護(RFC 7636)	最有力	中	verifier束縛・完全一致
パスキー(FIDO2/WebAuthn)	最有力	中	オリジン署名バインド
OIDC IDトークン検証	最有力	中	iss/aud/exp/nonce
OCSP / ステープリング	高	低	署名者はCA
mTLS / 送信者制約トークン	高	高	cert-bound/DPoP
PQC移行(ショア/ML-KEM)	高	中	ハイブリッド鍵交換

総括: 本分野は午前IIの定義問題(PKCE・OCSPステープリング・RFC 8705・ショア等)と、午後の実務シナリオ(パスワードレス認証・OAuth/PKI運用)の両面で狙われる。既存Web/暗号知識と接続する認証と認可の峻別、フィッシング耐性の本質=オリジン束縛、トークン盗難対策=鍵所有証明への束縛を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

ネットワーク・クラウド・ゼロトラスト

SASE/SSE/ZTNA/DMARC/DNSSEC/mTLS/PKCE。境界防御から「常に検証」へ移る時代の、アクセス統制・ドメイン認証・相互認証を代表5問で体系学習する。

Q1・SSE

SASEからSSEを切り出す

頻出 ★★★

Q2・ZTNA

VPN代替・アプリ単位認可

頻出 ★★★

Q3・DMARC

送信ドメイン認証の本質

頻出 ★★★

Q4・DNSSEC

完全性・出自認証(非暗号化)

頻出 ★★★

Q5・mTLS

相互TLS・証明書バウンド

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「アクセス経路の統制」→「通信・ドメインの真正性」で切り分ける学習動線

Q1

SSE

SASE=SD-WAN(NW)+SSE(セキュリティ)。SWG/CASB/ZTNAをクラウドで統合

クラウド境界 / 定義問題



Q2

ZTNA

VPNの過剰な信頼を排し、アプリ単位で認可・所在を秘匿

ゼロトラスト / 最小権限



Q3

DMARC

SPF/DKIM + アライメント検証。
none→quarantine→reject

ドメイン認証 / なりすまし



Q4

DNSSEC

RRSIG署名と信頼の連鎖で完全性・出自認証。暗号化はしない

DNS / 完全性≠機密性



Q5

mTLS

双方が証明書提示で相互認証。証明書バウンドトークンで盗用防止

サービス間通信 / RFC8705

STEP 1 | WHY

境界型(VPN)からゼロトラスト(SASE/SSE/ZTNA)へ移る全体像を理解する

STEP 2 | HOW

5問で「どの統制層・どの真正性」かを判別し、役割取り違えの選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(アプリ単位認可・段階運用・署名検証・相互認証)へ落とす

① 基礎概念 — 領域の全体像マップ

「何を統制するか(層)」×「何を守るか(目的)」で本デッキ5問を配置

CONCEPT

統制の層	アクセス経路の統制	通信・データの真正性	担う主な技術 / 本デッキ
クラウドエッジ	Q1 SSE=SWG/CASB/ZTNA/FWaaSをクラウド統合	TLSインスペクション／クラウド利用可視化	SASE / SSE / CASB
アクセス認可	Q2 ZTNA=アプリ単位で認可・所在秘匿	都度の端末/利用者評価(PDP/PEP)	ZTNA / NIST SP 800-207
メール / ドメイン	受信側でのなりすまし拒否ポリシー適用	Q3 SPF+DKIM+DMARC(アライメント)	SPF / DKIM / DMARC / BIMi
名前解決 / 経路	権威応答の受け入れ可否	Q4 DNSSEC=完全性・出自認証(非暗号化)	DNSSEC / DoH / DoT
サービス間通信	相互に相手を認証してから接続	Q5 mTLS=双方向証明書認証 + 証明書バウンド	mTLS / PKCE / OAuth 2.0

核心: この分野は「①どの層で統制するか(クラウドエッジ/認可/ドメイン/名前解決/サービス間)」と「②何を守るか(アクセス範囲の最小化/真正性・完全性/機密性)」の2軸で整理できる。**完全性・出自認証(DNSSEC・DKIM)**と**機密性・暗号化(DoH/DoT・TLS)**を混同しないことが最大の分岐点。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「役割・検証対象・保証する性質」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
SASE と SSE	SASE : SD-WAN(NW) + SSE (セキュリティ)を統合したフレームワーク	SSE : SASEから NW機能 を除いたセキュリティ機能群 (SWG/CASB/ZTNA/FWaaS)
ZTNA と VPN	ZTNA : アプリ単位で許可し、認可外アプリの 所在を秘匿	VPN : 接続端末を暗黙に信頼し セグメント全体 へ到達=横展開を助長
SPF と DKIM	DKIM : 秘密鍵署名を公開鍵で検証し 改ざん検知 + d=ドメイン正当性 (IP非依存)	SPF : エンベロープ From + 送信元IP を検証。ヘッダFrom詐称は防げない
DNSSEC と DoH/DoT	DNSSEC : 署名で 完全性・出自認証 。キャッシュポイズニング緩和	DoH/DoT : 通信路の 機密性(暗号化) 。完全性・出自認証は担わない
PDP と PEP	PDP : ポリシー 決定点 。端末/利用者状態を評価し認可を判断	PEP : ポリシー 実施点 。PDPの決定に従い接続を強制する地点

SASE Secure Access Service Edge

SD-WAN等のNW機能とSSEのセキュリティ機能をクラウドで一体提供する枠組み。
SASE≒SD-WAN + SSE。

 **Gartner** 提唱

ZTNA Zero Trust Network Access

最小権限でアプリ単位にアクセス許可し、ブローカ経由で認可外アプリの所在を秘匿。VPN代替。

 **NIST SP 800-207**

DMARC

SPF/DKIMの成功+ヘッダFromとのアライメント検証。none/quarantine/rejectを段階適用、rua/rufで可視化。

 **RFC 7489**

mTLS Mutual TLS

クライアント/サーバ双方が証明書を提示して相互認証。証明書バウンドトークンで盗用を抑止。

 **RFC 8705 (OAuth mTLS)**

SSE Security Service Edge

SASEからNW機能を除いた概念。SWG・CASB・ZTNA・FWaaS等をクラウドで統合提供。

 **Q1** の正解

CASB Cloud Access Security Broker

クラウド利用を可視化・制御。シャドーIT検出、未承認サービスへの持出し検知・遮断。

 **SSE** 構成要素

DNSSEC

RRSIG署名とDS/DNSKEYの信頼の連鎖で応答の完全性・出自認証を提供。暗号化は行わない。

 **RFC 4033~4035**

PKCE Proof Key for Code Exchange

code_verifierとcode_challenge(S256)で正規クライアントのみトークン交換可能に。認可コード横取り対策。

 **RFC 7636**

「どの規格が何を保証するか」を取り違えない

名称	根拠 / 種別	要点 (試験での問われ方)
SASE / SSE	Gartner 提唱	SASE=NW+セキュリティ。SSEはセキュリティ機能のみ(SWG/CASB/ZTNA/FWaaS)。Q1。
ZTNA	NIST SP 800-207	ゼロトラストの原則「常に検証」。アプリ単位認可、PDP/PEPでポリシー決定・実施。Q2。
SPF	RFC 7208	エンベロープFromと送信元IPを検証。ヘッダFrom詐称は防げない=DMARCのひっかけ。
DKIM	RFC 6376	秘密鍵署名・公開鍵検証で改ざん検知とd=ドメイン正当性を保証(IP非依存)。
DMARC	RFC 7489	SPF/DKIM+アライメント。none→quarantine→reject。 rua/rufで実態把握。Q3。
DNSSEC	RFC 4033~4035	完全性・出自認証(署名)。機密性是非対象=DoH/DoTと役割区別。Q4。
mTLS / PKCE	RFC 8705 / 7636	mTLS=相互認証+証明書バウンドトークン(Q5)。PKCE=認可コード横取り対策。

 **頻出の軸:** 「アクセス統制=SASE/SSE/ZTNA」「送信ドメイン認証=SPF/DKIM/DMARC」「DNSの完全性=DNSSEC・機密性=DoH/DoT」「相互認証・認可保護=mTLS/PKCE」。この役割取り違えが4択ひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. クラウド境界は**包含関係**で暗記：SASE⇒SSE⇒{SWG・CASB・ZTNA・FWaaS}。
2. ゼロトラストは「**常に検証**」。「一度信頼したら再認証省略」「セグメント全体到達」は必ず誤り。
3. 送信ドメイン認証は3点セット：**SPF=IP**/**DKIM=署名**/**DMARC=アライメント+ポリシー**。
4. DNSSECは**完全性・出自認証のみ**。暗号化(機密性)はDoH/DoTと言い切る。

⚠ よくあるひっかけ

- SSEに「SD-WAN(NW機能)」を含める→それはSASE。CSPM/CNAPP/XDRはクラウド資産側で別概念。
- 「SPFで検証しているから安心」→ヘッダFrom詐称は防げない(アライメント欠如)。
- 「DNSSECで通信が暗号化される」は誤り。逆にDoHに「署名検証」を混ぜるのも誤り。
- DMARCをいきなり**reject**で開始→正規メール誤ブロック。まず**none**で監視が定石。

合言葉：「どの層(クラウド/認可/ドメイン/DNS/サービス間)×何を守る(範囲最小化/真正性/機密性)」で分類 → 対策は「**アプリ単位認可・段階運用・署名検証・相互認証・最小権限**」に集約される。

SASE(Secure Access Service Edge)の構成要素のうち、SASEからSD-WANなどのネットワーク機能を除き、SWG・CASB・ZTNAといったセキュリティ機能群だけを指す概念はどれか。

ア CNAPP

イ CSPM

ウ SSE

エ XDR

正解 ウ ア=クラウドネイティブ保護基盤/イ=設定ミス検出のポスチャ管理/エ=多層検知・対応(EDR拡張)

▲ 空 (事実)

SASE ≡ SD-WAN(ネットワーク機能)+SSE(セキュリティ機能)という関係で捉えられる。

● 雨 (解釈)

SSEはSWG/CASB/ZTNA/FWaaS等をクラウドで統合提供する概念。CSPM/CNAPP/XDRはアクセス経路上のエッジではなく別概念。

✦ 傘 (対策)

アクセス経路のセキュリティはSSEに集約し、クラウド資産側の保護(CSPM/CNAPP)や検知(XDR)と役割分担する。

VPNの代替として用いられるZTNA(Zero Trust Network Access)の特徴として、最も適切なものはどれか。

ア 認証済み端末に対して社内ネットワークセグメント全体への到達性を付与する

イ アプリケーション単位でアクセスを許可し、認可されていないアプリの存在自体を秘匿する

ウ 送信元IPをACLに登録した端末だけを常時信頼し、以後の再認証を省略する

エ 拠点間をIPsecトンネルで接続し、境界ファイアウォールで一括制御する

正解 イ ア=VPNの過剰な信頼範囲／ウ=「常に検証」に反する／エ=従来の境界型NW

空 (事実)

ZTNAは最小権限に基づきアプリ単位でアクセスを許可し、ブローカを介した接続を行う。

雨 (解釈)

認可外アプリの所在(IP/ポート)を外部から秘匿。「一度信頼で再認証省略」はゼロトラスト原則(never trust, always verify)に反する。

傘 (対策)

セグメント全体を露出させず攻撃対象領域を縮小。都度、端末・利用者状態を評価(PDP)して認可する。

📎 実務メモ: 午後で頻出の「VPNの横展開(ラテラルムーブメント)を助長する理由」は暗黙の信頼+内部通信を都度検証しないこと。ZTNA移行の効果=攻撃対象領域の縮小と紐づけて記述できるか。

送信ドメイン認証に関する記述のうち、**DMARC**の説明として適切なものはどれか。

ア 許可メールサーバのIPをDNSのTXTに登録し、エンベロープFromの正当性を検証する

イ 送信側が秘密鍵で署名し、受信側がDNS公開の公開鍵で改ざんを検知する

ウ **SPF/DKIM**の成功に加え、認証済みドメインとヘッダ**From**の一致(アライメント)を検証し**none/quarantine/reject**を適用する

エ quarantine以上で運用するドメインに対し、メールクライアント上でブランドロゴを表示する

正解 ウ ア=SPF/イ=DKIM/エ=BIMI(DMARC enforcementが前提)

▲ 空 (事実)

DMARCはSPF/DKIMいずれかの認証成功に加え、認証済みドメインとヘッダFromのアライメントを要求する。

● 雨 (解釈)

SPFはエンベロープFrom、DKIMはd=ドメインとの一致。ヘッダFrom詐称を封じる点が本質。SPF/DKIM単体との違い。

↑ 傘 (対策)

rua/rufレポートで送信実態を可視化しつつ、ポリシーをnone→quarantine→rejectと段階適用する。

権威DNSサーバの応答の完全性・出自を公開鍵署名で検証する技術と、その技術が担わない役割に関する記述として、最も適切なものはどれか。

ア DNSSECはRRSIG署名とDS/DNSKEYの信頼の連鎖で完全性・出自認証を保證するが、通信路の暗号化は行わない

イ DNSSECはクエリ・応答の全体をTLSで暗号化し、経路上の盗聴を防止する

ウ DoHはリソースレコードに署名を付与し、キャッシュポイズニングを署名検証で防ぐ

エ DNSSECはカミンスキー攻撃の緩和に無効であり、権威応答の真正性は保証しない

正解 ア イ=DNSSECは暗号化しない/ウ=署名はDNSSECの役割/エ=カミンスキー攻撃緩和に有効

空 (事実)

DNSSECはRRSIG署名と、親ゾーンDSから子ゾーンDNSKEYへ至る信頼の連鎖を用いる。

雨 (解釈)

応答の完全性・出自認証(データ由来認証)を提供し、キャッシュポイズニング/カミンスキー攻撃の緩和に有効。ただしレコードは平文=機密性は非対象。

傘 (対策)

通信路の暗号化(機密性)はDoH/DoTの役割。完全性はDNSSEC、機密性はDoH/DoTと役割分担する。

ゼロトラストアーキテクチャ(NIST SP 800-207)やAPIのサービス間通信で用いられるmTLS(相互TLS)の説明として適切なものはどれか。

ア サーバ証明書のみを検証し、クライアントはパスワードで認証する片方向TLSである

イ クライアントとサーバの双方が証明書を提示して相互認証し、証明書にバインドしたトークン発行にも利用される

ウ TLSハンドシェイクを省略し、事前共有鍵のみで通信を高速化する方式である

エ クライアント証明書の代わりにSPFレコードで送信元の正当性を検証する方式である

正解 イ ア=通常のサーバ認証型(片方向)TLS/ウ・エ=mTLSと無関係

空 (事実)

mTLSはサーバ・クライアント双方が証明書を提示して相互認証を行うTLSである。

雨 (解釈)

ゼロトラストのサービス間通信やAPI保護に用いる。OAuth 2.0のmTLS(RFC 8705)は発行トークンをクライアント証明書に紐づける。

傘 (対策)

証明書バウンドトークンにより、トークンが盗まれても対応する証明書がなければ悪用できず、盗用を防止する。



午後 記述式 — シナリオ要点

ゼロトラスト移行・SASE/SSE導入／メールセキュリティ・DNS運用

記述

◆ 問1 (秋想定) ZT移行とSSE導入(S社)

- 全社VPNの横展開の原因 = 接続端末を暗黙に信頼し内部通信を都度検証しない信頼モデル。
- ZTNA置換の効果 = アプリ単位許可でセグメント全体を露出させず、攻撃対象領域を縮小。
- SaaS可視化・シャドーIT統制を担うのはCASB(未承認サービスへの持出し検知・遮断)。
- 認可を判断する論理コンポーネント = PDP(ポリシー決定点)。PEPと取り違えない。

◆ 問2 (春想定) メール認証とDNS運用(F社)

- SPFのみで防げない理由 = 検証対象はエンベロープFrom + IP、ヘッダFrom詐称は検知不可。
- DKIM導入で可能に = ①署名によるヘッダ/本文の改ざん検知②d=ドメインの正当性(IP非依存)。
- DMARCはnone(監視)から開始 = 設定漏れ・正規転送の誤ブロックを回避しつつ実態把握。
- 送信実態の把握 = rua(集計レポート)を活用(rufも可)。BIMI等の無関係機能は誤り。

採点の分水嶺: ①VPNは「暗黙の信頼・都度検証しない」と本質を突く ②ZTNAは「アプリ単位+セグメント非露出」の2点 ③CASBとPDPを正しく指名 ④SPFの検証対象とアライメントの前提 ⑤DMARCはnoneが監視モードである運用理由まで踏み込んでいるか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でネットワーク・クラウド・ゼロトラスト論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策・キーワード
SASE / SSE (クラウド境界)	最有力	低	包含関係で暗記
ZTNA / ゼロトラスト	最有力	中	アプリ単位認可/PDP
DMARC / SPF / DKIM	最有力	中	アライメント/段階運用
DNSSEC (完全性≠機密性)	高	中	署名検証/DoH区別
mTLS / PKCE (認証・認可保護)	高	高	相互認証/証明書バウンド

総括: この分野は午前IIの概念定義(SSE・ZTNA・DMARC・DNSSEC・mTLS)と、午後の実務シナリオ(VPN→ゼロトラスト移行、なりすまし対策)の両輪で狙われる。役割の取り違い(SASE⇒SSE、完全性≠機密性、SPF≠アライメント、PDP≠PEP)を潰し、対策語彙「**アプリ単位認可・段階運用・署名検証・相互認証・最小権限**」を確実に書けるようにすること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

Web/アプリケーション脆弱性

OWASP/SQLi・XSS・CSRF・SSRF/セキュアコーディング。午前IIの用語判別から午後の設計・実装対策まで、頻出6論点を5問で体系学習する。

Q1・SSRF

メタデータ窃取/宛先偽装

頻出 ★★★

Q2・SQLi

ブレースホルダの本質

頻出 ★★★

Q3・XSS

格納型XSSの識別

頻出 ★★★

Q4・CSRF

SameSite属性の役割

頻出 ★★★

Q5・Path

ディレクトリトラバーサル

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3〜7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「注入(インジェクション)」と「セッション・認可」の2系統で切り分ける学習動線

Q1

SSRF

サーバに任意宛先へ要求させ、クラウドのメタデータ(169.254.169.254)から認証情報を窃取

許可リスト + IP検査



Q2

SQLi

入力をSQLの構文要素として解釈させる注入。ブレースホルダで構文とデータを分離

バインド機構



Q3

XSS

出力に混入したスクリプトが被害者ブラウザで実行。格納型は永続化・無差別配信

出力エスケープ



Q4

CSRF

他サイト起点の状態変更要求。SameSiteでCookie自動送信を抑制、トークンで照合

トークン + SameSite



Q5

Traversal

「../」でバス外参照。識別子化 + 正規化後に基準ディレクトリ配下を検証

canonicalize

STEP 1 | WHY

OWASP Top10 の攻撃を「注入系」と「セッション・認可系」の全体像で理解する

STEP 2 | HOW

5問で「どの脆弱性か」を経路と結果から判別し、ひっかけ選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(構文分離・出力エスケープ・許可リスト・正規化検証)へ落とす

① 基礎概念 — Webアプリ脆弱性 分類マップ

攻撃の「起点」と「本質(何が壊れるか)」の2軸で本デッキ5問を配置

CONCEPT

系統 / 本質	注入系 (構文・命令の混入)	セッション・認可系 (なりすまし・越境)
利用者入力 経由	Q2 SQLインジェクション／ Q3 XSS(反射・DOM・格納)／OSコマンドインジェクション	セッションフィクセーション／セッションハイジャック
サーバ挙動 経由	Q1 SSRF(サーバに任意宛先へ要求)／ Q5 ディレクトリトラバーサル	オープンリダイレクト／認可不備(IDOR)
他サイト 経由	HTTPヘッダインジェクション	Q4 CSRF／クリックジャッキング

核心: 注入系は「データが構文・命令として解釈される」ことが本質で、対策は構文とデータの分離/エスケープ。セッション・認可系は「本人性・権限の検証不足」が本質で、対策はトークン照合・属性・正規化検証。この2系統に落とし込めば4択も午後も切れる。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「起点・成立条件・対策」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
XSSの分類	格納型：スクリプトがサーバ側に永続化され閲覧者へ無差別配信	反射型/DOM型：その要求限りで応答反映(反射)、DOM操作過程で実行(DOM)
Cookie属性	HttpOnly：JSからの読取を禁止しXSSでのCookie窃取を緩和	SameSite：他サイト起点のCookie自動送信を抑制しCSRFを緩和(Secure=HTTPS限定送信)
SQLi対策の本質	プレースホルダ：入力をデータとして固定し構文構造を変えない	エスケープ/危険文字除去：表層的で漏れ・多重表現で回避され得る
SSRFと類似	SSRF：サーバに任意宛先へ要求させる(内部・メタデータ狙い)	オープンリダイレクト：利用者ブラウザを任意サイトへ誘導
パス系の攻撃	ディレクトリトラバーサル：正規化後に基準配下か検証	OSコマンドインジェクション：シェルを介さないAPI利用で根絶

③ 基礎概念 — 必須用語集

Webアプリ脆弱性5問を解く8用語

CONCEPT

SSRF Server-Side Request Forgery

サーバに任意宛先へHTTP要求を送らせる。クラウドのIMDS(169.254.169.254)から一時認証情報を窃取する経路に悪用。

 **OWASP Top10 A10:2021**

格納型XSS Stored / Persistent XSS

スクリプトがDB・ログ等に永続化され、閲覧者へ継続的・無差別に配信・実行される。反射型・DOM型と区別。

 **OWASP A03:2021 Injection**

SameSite属性

クロスサイト要求へのCookie自動送信を抑制(Lax/Strict)しCSRFを緩和。トークンの代替ではなく補強。

 **RFC 6265bis**

ディレクトリトラバーサル Path Traversal

「../」等でパス外を参照。ファイル名を識別子化、または正規化(canonicalize)後に基準配下を検証して根絶。

 **CWE-22**

プレースホルダ / バインド機構 Prepared Statement

SQLの構文構造を事前確定し、後続の入力値を常にデータとして扱う。テーブル名・列名はバインド不可で許可リスト対処。

 **SQLi の本質対策**

CSRF Cross-Site Request Forgery

被害者の認証済みセッションを悪用し、他サイト起点で意図しない状態変更要求を送らせる。トークン照合が本質対策。

 **OWASP A01:2021 関連**

HttpOnly / Secure属性

HttpOnly=JSからのCookie参照禁止(XSS窃取緩和)。Secure=HTTPS接続時のみ送信(盗聴緩和)。

 **RFC 6265**

IMDSv2 Instance Metadata Service v2

セッション指向・トークン必須(PUT)・ホップ制限でSSRF単独からの認証情報窃取を困難化。v1は無効化推奨。

 **クラウド基盤側の緩和**

④

基礎概念 — 脆弱性 × 根本対策 マトリクス

「本質対策」と「表層策(不十分)」を取り違えない

CONCEPT

脆弱性(規格)	根本対策(正解語彙)	不十分・ひっかけ
SSRF (A10:2021)	宛先の許可リスト + 名前解決後IP検査(内部・リンクローカル遮断) + リダイレクト再検証	単なるURL文字列フィルタ。IMDSv2化・権限最小化は基盤側の緩和で併用。
SQLi (A03:2021)	ブレースホルダ(バインド機構)で構文とデータを分離	危険文字のエスケープ/除去のみ、通信のTLS化(注入とは無関係)。
XSS (A03:2021)	出力時のコンテキスト依存エスケープ、装飾許可は許可リスト型サニタイズ + CSP	入力エスケープのみ、ブラックリスト方式の個別除去は回避されやすい。
CSRF (A01関連)	推測困難なCSRFトークンの発行・照合 + SameSite属性で補強	Referer/Origin検証のみは限定的。SameSite単独で完全代替は不可。
Path Traversal (CWE-22)	入力を識別子に限定、または正規化後に基準ディレクトリ配下を検証	「../」の単純除去。エンコード・多重表現で回避される。
セッション管理	ログイン直後の再発行、HttpOnly + Secure、タイムアウト	セッションIDをURLに付与(Referer・履歴・ログで漏えい)。

💡 頻出の軸: 「注入系は構文/データ分離・出力エスケープ」「セッション認可系はトークン・属性・正規化検証」。表層策(危険文字除去・入力エスケープのみ・URL文字列フィルタ)を正解に見せる4択のひっかけが定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. XSSは**3分類**で判別：永続化=格納型／応答反映=反射型／DOM操作過程=DOM型。
2. SQLi対策の本質は「**入力をデータとして固定し構文構造を変えない**」=ブレースホルダ。
3. Cookie属性は役割で暗記：HttpOnly=XSS窃取緩和／SameSite=CSRF緩和／Secure=盗聴緩和。
4. SSRFは「**サーバに要求させる**」+許可リスト+名前解決後**IP検査**が正解語彙。

⚠ よくあるひっかけ

- XSS対策を「**入力エスケープ**」で済ませたつもり→出力処理漏れで成立。
- SSRFとオープンリダイレクトの混同：SSRFはサーバ、リダイレクトはブラウザが動く。
- 「../」の**単純な文字列除去**は多重表現・エンコードで回避され不十分。
- SameSiteやReferer/Origin検証を**CSRFの本質対策**として単独で選ばせる。

合言葉：「起点(どこから)×本質(何が壊れるか)」で分類 → 対策は「**構文分離・出力エスケープ・許可リスト・正規化検証・トークン照合**」の5語彙に集約される。

クラウド環境のインスタンスメタデータエンドポイント(例:169.254.169.254)へアプリケーションサーバから意図しないHTTPリクエストを送信させ、一時的な認証情報を窃取する攻撃の名称はどれか。

ア クリックジャッキング

イ サーバサイドリクエストフォージェリ(SSRF)

ウ セッションフィクセーション

エ ディレクトリトラバーサル

正解 イ ア=iframeで操作誘導/ウ=セッションID固定化/エ=パス外ファイル参照

▲ 空 (事実)

サーバに任意宛先へ要求させ、リンクローカルのIMDS(169.254.169.254)から一時認証情報を取得できた。

☝ 雨 (解釈)

SSRFはメタデータサービスや内部システムへの到達経路として悪用される。窃取した認証情報でIAM権限を悪用される。

☂ 傘 (対策)

宛先の許可リスト化、名前解決後IPの検査で内部・リンクローカル宛てを遮断、IMDSv2への移行。

プレースホルダ(バインド機構)を用いたSQL文の組み立てが、SQLインジェクション対策として有効である最も本質的な理由はどれか。

ア SQL文が実行前に暗号化され、通信経路上で解読されないため

イ 入力値がSQL文の構文要素ではなくデータ(値)としてのみ扱われ、構文構造が変化しないため

ウ 危険な文字列を検出した時点でDBMSがトランザクションをロールバックするため

エ アプリケーションからDBへの接続がTLSで保護され改ざんが検知されるため

正解 イ ア・エ=通信保護でSQLi無関係/ウ=そのような自動ロールバック機構はない

空 (事実)

SQL文の構文構造を事前にコンパイル確定させ、後からバインドする入力値は常にデータとして扱う。

雨 (解釈)

入力の引用符やSQL断片が構文として解釈されず注入が成立しない。アプリのエスケープ処理に依存しない点が本質。

傘 (対策)

プレースホルダを徹底。テーブル名・列名など構文要素の動的指定はバインド不可のため許可リストで別途対処。

実務メモ: 「エスケープ」ではなく構文とデータの分離が正解語彙。動的な識別子(列名・ソート順)を受け取る箇所だけは許可リストで固める、まで書ければ午後で加点。

OWASP Top 10(2021)で「Injection」に分類されるXSSのうち、格納型(蓄積型)XSSの説明として適切なものはどれか。

ア 攻撃者が仕込んだスクリプトがDBやログなどサーバ側に永続化され、当該データを閲覧した利用者のブラウザで実行される

イ URLパラメータに含まれるスクリプトが応答にそのまま反映され、被害者がリンクを踏んだ際に実行される

ウ サーバへのスクリプト送信を伴わず、クライアント側JavaScriptが入力をDOMへ反映する過程で実行される

エ 正規サイトを透過的なiframeで覆い、利用者の操作を誘導してクリックさせる

正解 ア イ=反射型XSS/ウ=DOM Based XSS/エ=クリックジャッキング

▲ 空 (事実)

スクリプトがサーバ側に永続化され、閲覧者へ継続的・無差別に配信される。

● 雨 (解釈)

格納型は被害が広範かつ持続的。反射型(その要求限り)・DOM型(クライアント内)と成立経路が異なる。

✦ 傘 (対策)

出力時のコンテキスト依存エスケープ。装飾許可なら許可リスト型サニタイズ+CSP+Cookieに HttpOnly。

Cookieに設定する属性のうち、CSRFの緩和を主目的として、他サイトを起点とするクロスサイトリクエストにCookieを送信させないように制御する属性はどれか。

ア Secure属性

イ HttpOnly属性

ウ SameSite属性

エ Domain属性

正解 ウ ア=HTTPS接続時限定送信/イ=JSからの読取防止(XSS窃取緩和)/エ=送信対象ドメイン指定

▲ 空 (事実)

SameSite(Lax/Strict)はクロスサイト要求へのCookie自動送信を抑制する。

☛ 雨 (解釈)

CSRFの緩和に寄与するが緩和策であり、CSRFトークンによる照合を代替するものではない。

☂ 傘 (対策)

本質対策は推測困難なCSRFトークンの発行・照合。SameSite属性を付与して補強する。

「../」などを含む入力で公開ディレクトリ外のファイルを不正に参照される脆弱性の名称と、その根本対策として適切な組合せはどれか。

ア OSコマンドインジェクション — シェルを介さないAPIの利用

イ ディレクトリトラバーサル — 入力を識別子に限定し、正規化後に許可ディレクトリ配下か検証する

ウ HTTPヘッダインジェクション — 改行コードの除去

エ オープンリダイレクト — リダイレクト先の許可リスト化

正解 イ ア・ウ・エ=別脆弱性と対策の正しい組だが本設問(バス外参照)には非該当

▲ 空 (事実)

バスの相対参照(../)を悪用し、基準ディレクトリ外のファイルを参照される。

☂ 雨 (解釈)

「../」の単純な文字列除去はエンコードや多重表現で回避され得るため不十分。

☂ 傘 (対策)

ファイル名を直接受けず識別子経由で解決、または正規化(**canonicalize**)後に基準配下であることを検証。



午後 記述式 — シナリオ要点

SaaS経費精算のSSRF／掲示板の格納型XSS・CSRF

記述

◆ 問1（春想定）連携先URL取得機能のSSRF

- 利用者入力URLへサーバが要求→**SSRF**。IMDS(169.254.169.254)で一時認証情報が画面表示。
- 被害 = 窃取した認証情報を外部から再利用し、IAM権限でオブジェクトストレージの他利用者データを読取・改ざん・削除(横方向アクセス)。
- 入力対策 = ①宛先FQDNの許可リスト限定 ②名前解決後IP検査でループバック/リンクローカル/プライベート遮断+リダイレクト再検証。
- 基盤側 = **IMDSv2化**・**v1無効化** + IAMロール権限最小化。

◆ 問2（秋想定）掲示板の格納型XSS・CSRF

- 自己紹介文にHTML保存許可→**格納型XSS**。**onerror**付imgが描画時に発火し**document.cookie**を外部送信。
- HttpOnly未設定でCookie窃取→セッション乗っ取り→なりすまし投稿。
- 装飾許可の対策 = 許可リスト型**HTMLサニタイズ**(実績あるライブラリ)を出力時に実施。
- CSRF根本対策 = セッション単位の推測困難な**トークン照合** + SameSiteで補強。

採点の分水嶺: ①SSRFと明記し被害を**認証情報の外部再利用による横断アクセス**まで具体化 ②対策は「危険文字除去」でなく**許可リスト + 名前解決後IP検証** ③XSSは**格納型 + 出力時サニタイズ** + HttpOnly ④CSRFは**トークン照合**まで踏み込めているか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でWebアプリ脆弱性論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
SSRF / メタデータ窃取	最有力	高	許可リスト + IP検査
SQLi / プレースホルダ	最有力	中	構文/データ分離
XSS(格納/反射/DOM)	最有力	中	出力エスケープ
CSRF / Cookie属性	高	中	トークン + SameSite
Path Traversal / セッション管理	高	低	正規化検証

総括: Webアプリ脆弱性は午前IIの用語・分類判別(XSS3分類・Cookie属性の役割・SSRF/リダイレクトの主体差)と、午後の設計・実装対策(SSRF・格納型XSS・CSRF)の両面で狙われる。近年台頭の**SSRF(クラウド認証情報窃取)**と、依然定番の**XSS/SQLi**を最優先で固め、対策は必ず**表層策**でなく**本質対策**の語彙で書けるようにすること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

AIセキュリティ・LLM

OWASP Top 10 for LLM／プロンプトインジェクション／RAG／AIエージェント／MITRE ATLAS。「出る出ると言われ続けて未出題」の最有力テーマを5問で体系学習する。

Q1・LLM01

間接プロンプトインジェクション

頻出 ★★★

Q2・LLM05

不適切な出力処理
→XSS/SQLi連鎖

頻出 ★★★

Q3・Framework

MITRE ATLAS の位置づけ

頻出 ★★★

Q4・LLM08

ベクトルと埋め込みの脆弱性

頻出 ★★★

Q5・LLM06

過剰な代理権限(AIエージェント)

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

攻撃の「経路」と「フェーズ」で切り分ける学習動線

MAP

Q1

間接PI

外部データ(Web/メール/PDF)に指示を潜ませ、利用者を介さず実行

LLM01 / 直接PIと対比



Q2

出力処理

LLM出力を無検証で下流へ
→XSS/SQLi/コマンドインジェクションに連鎖

LLM05 / Webセキュ接続



Q3

ATLAS

攻撃TTPを体系化。ATT&CKのAI版。RMF/42001と区別

Framework / 定義問題



Q4

ベクトルDB

RAGの権限フィルタ不備→他部署・他テナント文書が漏えい

LLM08 / RAG分離



Q5

過剰権限

エージェントの権限・自律性が過大→注入指示で高影響操作まで実行

LLM06 / 最小権限

STEP 1 | WHY

OWASP LLM Top10 と攻撃分類(経路×フェーズ)の全体像を理解する

STEP 2 | HOW

5問で「どのLLMリスクか」を判別し、ひっかけ選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(分離・最小権限・出力エスケープ・権限フィルタ)へ落とす

① 基礎概念 — OWASP LLM Top10 分類マップ

攻撃の「経路」と「フェーズ」の2軸で本デッキ5問を配置

CONCEPT

軸 / リスク	学習時(Training)	推論時・入力(Inference / Input)	出力・下流(Output / Downstream)
利用者入力 経由	—	直接プロンプトインジェクション(LLM01)/ジェイルブレイク	Q2 不適切な出力処理(LLM05) →XSS/SQLi/コマンドインジェクション/SSRF
外部データ 経由	データ/モデルのポイズニング(LLM04)	Q1 間接プロンプトインジェクション(LLM01)	
検索・データ層	Q4 ベクトルと埋め込みの脆弱性(LLM08)/機密情報漏えい(LLM02)		システムプロンプト漏えい(LLM07)/誤情報(LLM09)
エージェント / 資源	Q5 過剰な代理権限(LLM06)		無制限消費(LLM10)

核心: LLMリスクは「①どこから入るか(利用者入力/外部データ/検索層/ツール)」と「②いつ起きるか(学習時/推論時/出力時)」の2軸で切り分けられる。Q3のMITRE ATLASは、この攻撃TTP全体を体系化するナレッジベースとして俯瞰の役割を担う。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「経路・フェーズ・対策」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
PIの経路	直接PI：利用者が入力欄に「指示を無視せよ」と自ら注入	間接PI：Web/メール/PDF等外部データに潜む指示をLLMが読み込み実行
攻撃フェーズ	回避攻撃(敵対的サンプル)：推論時に微小摂動で誤分類	データポイズニング：学習時にデータ汚染でバックドア
出力の扱い	LLM出力を信頼境界の外側として出力時にエスケープ(LLM05対策)	入力のエスケープだけで対策したつもり＝出力処理漏れでXSS成立
データ復元系	モデル反転／メンバーシップ推論：出力から学習データを推定	モデル抽出(窃取)：大量クエリでモデル機能を複製
エージェント統制	最小権限＋高影響操作に人間承認(HITL)	全ツールをLLM判断で自動実行＝過剰な代理権限(LLM06)

③ 基礎概念 — 必須用語集

AIセキュリティ5問を解く8用語

CONCEPT

プロンプトインジェクション Prompt Injection

指示とデータを同一チャンネルで処理する性質を突き、意図しない指示を実行させる。利用者入力経由=直接、外部データ経由=間接。

 OWASP LLM01:2025

ベクトルと埋め込みの脆弱性 Vector & Embedding

RAGのベクトルDBのアクセス制御不備・テナント分離不足で横断的情報漏えい。埋め込みからの元データ復元も。

 OWASP LLM08:2025

MITRE ATLAS

ATT&CKをAI機械学習向けに拡張し、攻撃戦術×技法(TTP)を実事例で体系化したナレッジベース。脅威分析の共通言語。

 ATT&CK の AI 版

ジェイルブレイク Jailbreak

言い回しやロールプレイでガードレール(安全機構)を回避し、禁止された出力を引き出す。

 ガードレール回避

不適切な出力処理 Improper Output Handling

LLM出力を無検証で下流(ブラウザ/DB/OS/API)へ渡し、XSS・SQLi・コマンドインジェクション・SSRF・RCEに連鎖。

 OWASP LLM05:2025

過剰な代理権限 Excessive Agency

エージェントの機能・権限・自律性が過大で、誤動作や注入成立時の被害が拡大。最小権限+人間承認が定石。

 OWASP LLM06:2025

敵対的サンプル / 回避攻撃 Adversarial / Evasion

推論時に人間には知覚しにくい微小な摂動を入力へ加え、分類器に誤分類を起こさせる。

 推論時攻撃

human-in-the-loop HITL

影響の大きい/不可逆な操作(外部送信・削除・決済)の実行前に人間の承認を挟む統制。

 LLM06 の定番対策

④ 基礎概念 — フレームワーク・規格マトリクス

「攻撃TTP／防御／リスク管理／認証規格」を混同しない

CONCEPT

名称	種別	要点（試験での問われ方）
MITRE ATLAS	攻撃TTPの体系化	ATT&CKのAI版。「戦術×技法」でAIへの攻撃を整理。 Q3の正解 。攻撃側の知識ベース。
MITRE ATT&CK	攻撃TTPの体系化(汎用)	実観測の攻撃者の振る舞い(TTP)を分類。ATLASの母体。第5分野(攻撃・IR)と接続。
MITRE D3FEND	防御技術の体系化	対策側のマッピング 。攻撃TTPの体系化ではない=Q3のひっかけ。
NIST AI RMF	リスク管理FW	GOVERN/MAP/MEASURE/MANAGEでAIリスクを管理。攻撃TTP体系ではない。
ISO/IEC 42001	認証規格(AIMS)	AIマネジメントシステムの認証規格。ISMS(27001)のAI版という位置づけ。
AI事業者ガイドライン	国内ガイドライン	総務省・経産省。開発者/提供者/利用者の3主体区分。組織統制の根拠。

💡 **頻出の軸:** 「攻撃を体系化=ATLAS/ATT&CK」 「防御を体系化=D3FEND」 「リスク管理=AI RMF」 「認証規格=ISO/IEC 42001」。この4分類の取り違えが4択のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. PIは経路で判別。利用者入力=直接/外部データ(Web・メール・PDF・検索結果)=間接。
2. LLM05は「出力を信頼境界の外側として扱う」。対策は出力時のエスケープ/サニタイズ。
3. フレームワークは4分類で暗記：攻撃=ATLAS/ATT&CK、防御=D3FEND、管理=AI RMF、規格=42001。
4. エージェント問題は最小権限 + HITL(人間承認) + 監査ログが正解語彙。

⚠ よくあるひっかけ

- LLM05を「入力のエスケープ」で対策したつもり→出力処理漏れてXSS成立。
- 「大量クエリでコスト増」=LLM10無制限消費。PIやポイズニングと混同しない。
- 回避攻撃(推論時)とポイズニング(学習時)のフェーズ取り違い。
- エージェント対策で「自動実行で速度優先」「システムプロンプトを応答に含める」は逆効果。

合言葉：「経路(どこから)×フェーズ(いつ)」で分類 → 対策は「分離・最小権限・出力エスケープ・権限フィルタ・人間承認」の5語彙に集約される。

OWASP Top 10 for LLM 2025 における「間接プロンプトインジェクション」に該当する攻撃はどれか。

ア 入力欄に「これまでの指示を無視せよ」と直接打ち込み制約を解除させる

イ 公開Webページやメール本文に視認しにくい指示文を埋め込み、RAGや要約でLLMに実行させる

ウ APIに大量かつ長大な推論要求を送り、応答遅延とコスト増を起こす

エ 学習用データに悪意あるサンプルを混入させバックドアを仕込む

正解 イ ア=直接PI(LLM01)/ウ=無制限消費(LLM10)/エ=データ・モデルのポイズニング(LLM04)

空 (事実)

利用者の直接入力ではなく、LLMが処理対象として取り込む外部データに指示が潜んでいる。

雨 (解釈)

利用者を介さず実行される点が「間接」の核心。指示とデータを同一チャンネルで処理する構造が原因。

傘 (対策)

取り込む外部データを検証・無害化し、指示とデータを分離。要約対象データにソール実行権限を与えない。

OWASP LLM05:2025 「不適切な出力処理」に起因する被害として最も適切なものはどれか。

ア LLM生成のHTML/スクリプトを無検証で埋め込み格納型XSS、あるいは生成文字列をそのままOS/SQLに渡しコマンド/SQLインジェクションに連鎖

イ MFAの時刻同期ずれてOTP検証に失敗し正規利用者がログイン不可

ウ ベクトルDBのアクセス制御不備で他テナント文書が検索結果に混入

エ エージェントに過大なツール権限を与え意図しない外部操作が行われる

正解 ア イ=認証運用の可用性問題(LLM無関係)/ウ=LLM08/エ=LLM06

空 (事実)

LLM出力を検証せず、下流のブラウザ・DB・OS・APIへそのまま渡している。

雨 (解釈)

LLM出力=信頼できない外部入力。既存のインジェクション脆弱性(XSS/SQLi/RCE)へ連鎖する。

傘 (対策)

出力を信頼境界の外側として扱い、出力時にコンテキスト依存のエスケープ/サニタイズ+CSP。

📌 実務メモ: ここは既存Webアプリセキュリティ(第3分野)と直結する午後の狙い目。「入力エスケープ」ではなく出力エスケープと書けるかが分水嶺。

AIシステムへの攻撃を体系化したナレッジベースであり、MITRE ATT&CK の考え方をAI/機械学習システムの攻撃戦術・技法(TTP)に拡張したものはどれか。

ア MITRE D3FEND

イ MITRE ATLAS

ウ NIST AI RMF

エ ISO/IEC 42001

正解 イ ア=防御技術の体系化/ウ=リスク管理FW/エ=AIMS認証規格

空 (事実)

「戦術×技法」マトリクス形式で、AI/MLへの攻撃TTPを実事例に基づき整理したもの。

雨 (解釈)

ATT&CKの“AI版”。攻撃を体系化=ATLAS、防御=D3FEND、管理=RMF、規格=42001の4分類で判別。

傘 (対策)

脅威分析・検知/対策検討の共通言語として活用。CSIRTのインシデント整理に用いる。

RAGを用いた社内文書検索チャットボットにおいて、LLM08:2025「ベクトルと埋め込みの脆弱性」として顕在化するリスクはどれか。

ア 回答の根拠が提示されず利用者が誤情報を過度に信頼する

イ ベクトルDBの権限フィルタリング不足で、閲覧権限のない他部署・他テナント文書を検索取得できる

ウ システム指示が応答に出力され内部構成が推測される

エ 長大コンテキストの投入で推論コストが急増する

正解 イ ア=誤情報(LLM09)/ウ=システムプロンプト漏えい(LLM07)/エ=無制限消費(LLM10)

▲ 空 (事実)

RAGのベクトルDBにアクセス制御・テナント分離の不備がある。

● 雨 (解釈)

埋め込み/検索層固有の脆弱性。横断的な情報漏えい、埋め込みからの元データ復元が中心。

↑ 傘 (対策)

検索時に利用者の権限で結果をフィルタリング、部署ごとにインデックス/テナント分離。

LLM06:2025 「過剰な代理権限」を持つAIエージェントのリスクを低減する対策として、最も適切なものはどれか。

ア すべてのツール呼び出しをLLMの判断のみで自動実行し応答速度を最優先

イ ツール・権限・自律性を最小化し、高影響操作(外部送信・削除・決済)の実行前に人間承認(HITL)を挟む

ウ 出力トークン数の上限を撤廃しより詳細な応答を返す

エ システムプロンプトを応答に含めて挙動を検証できるようにする

正解 イ ア=自律性・権限を最大化し逆効果/ウ=LLM10助長/エ=LLM07招く

空 (事実)

エージェントに与えた機能・権限・自律性が過大。

雨 (解釈)

誤動作やプロンプトインジェクション成立時に、注入指示が高影響操作まで実行され被害拡大。

傘 (対策)

最小権限・ツール制限+不可逆/高影響操作への人間承認+操作の監査ログ化。



午後 記述式 — シナリオ要点

RAGチャットボット導入/AIエージェント・ガバナンス

記述

◆ 問1 (秋想定) 社内RAGチャットボット

- 単一インデックス・権限チェック無し → **LLM08**。対策=検索時の権限フィルタ + インデックス分離。
- 外部PDFの指示で顧客リスト出力 → **間接プロンプトインジェクション**。原因=外部データを検証せずシステムプロンプトへ連結(指示とデータ未分離)。
- 生成結果をHTMLに無検証埋め込み → **格納型XSS**。対策=出力エスケープ + CSP。

◆ 問2 (春想定) AIエージェント・ガバナンス

- 社外へファイル送信の直接要因 = **LLM06 過剰な代理権限** + **LLM01 間接PI**の2軸。
- 対策 = 最小権限・HITL(高影響操作の事前承認)・指示とデータの分離。
- **MITRE ATLAS** = ATT&CKのAI拡張で攻撃TTPを体系化した共通言語。
- 組織統制 = 入力禁止情報の規程化/シャドーAI禁止(承認制)。

採点の分水嶺: ①「間接」PIと明示 ②「出力時」エスケープ ③エージェントは**最小権限 + HITL** ④組織統制は**入力禁止情報の規程化・シャドーAI防止**まで踏み込めているか。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でAIセキュリティ論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
間接プロンプトインジェクション(LLM01)	最有力	中	指示/データ分離
不適切な出力処理(LLM05)	最有力	中	出力エスケープ
過剰な代理権限(LLM06)	最有力	高	最小権限 + HITL
ベクトル/埋め込み(LLM08)	高	中	権限フィルタ/分離
MITRE ATLAS / RMF / 42001	高	低	4分類で暗記

総括: AIセキュリティは午前IIの用語定義(ATLAS・敵対的サンプル・ジェイルブレイク等)と、午後の実務シナリオ(RAG・AIエージェント)の両方で狙われる。既存のWebセキュリティ知識(XSS/SQLi)と接続する**LLM05**、エージェント時代の目玉**LLM06**を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

マルウェア・攻撃手法・インシデント対応

MITRE ATT&CK／ランサムウェア／EDR/XDR/MDR／フォレンジック。侵入から横展開・被害・検知・証拠保全までの「攻防のライフサイクル」を5問で体系学習する。

Q1・Framework**MITRE ATT&CK の TTP
3階層**

頻出 ★★★

Q2・Ransomware**イミュータブルバックアップ運用**

頻出 ★★★

Q3・Detection**EDR / XDR / MDR の違い**

頻出 ★★★

Q4・Forensics**揮発性の順序(Order of Volatility)**

頻出 ★★★

Q5・Lateral**Pass the Hash による横展開**

頻出 ★★★

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「共通言語 → 侵入・横展開 → 被害 → 検知 → 証拠保全」の攻防ライフサイクル

Q1

ATT&CK

攻撃者の振る舞いを
Tactics/Techniques/Procedures
で体系化。全問の共通言語

Framework / 定義問題



Q5

横展開

Pass the Hash で平文復元
なしに他システムへ認証。
Lateral Movement

攻撃技法 / T1550.002



Q2

ランサム

暗号化+窃取。バックアップ
も破壊される→イミュータブル/
オフライン

Impact / 3-2-1



Q3

検知/対応

EDR→XDR(横断相
関)→MDR(運用代行)。検
知・封じ込め基盤

SOC / 監視体制



Q4

保全

揮発性の高い順(メモリ→デ
ィスク)に証拠保全。ライブ
採取が要

Forensics / 事後対応

STEP 1 | WHY

攻撃を「戦術×技法(TTP)」で捉え、キルチェーン
との違いと攻防の全体像を掴む

STEP 2 | HOW

5問で「攻撃技法／検知製品／保全原則」を判別
し、混同ひっかけを切る

STEP 3 | WHAT

空-雨-傘で対策(MFA・イミュータブル・振る舞い
検知・ライブ保全)へ落とす

① 基礎概念 — 攻撃ライフサイクルと本デッキの配置

キルチェーン(線)× ATT&CK 戦術(面)の2軸で5問と主要技法を俯瞰

CONCEPT

キルチェーン段階	対応する ATT&CK 戦術(例)	代表技法・本デッキ論点
配送・エクスプロイト	Initial Access	VPN 不正ログイン(MFA未導入・パスワード使い回し)/フィッシング
インストール・C2	Execution / Command & Control	正規プロセスからの PowerShell 実行(LotL)/コネクトバック通信
目的の実行(内部活動)	Credential Access / Lateral Movement	LSASS ダンプ/Q5 Pass the Hash(T1550.002)=横展開
目的の実行(被害)	Impact	Q2 ランサムウェア(二重脅迫)/バックアップ暗号化
検知・対応・事後	Detection / Response(防御側)	Q3 EDR/XDR/MDR / Q4 フォレンジック(揮発性順) / 全体を Q1 ATT&CK で整理

核心: キルチェーンは偵察～目的実行を並べた直線(線)のモデル、ATT&CK は順序を前提としない網羅マトリクス(面)。攻撃の各段階を Q1 ATT&CK の戦術で言語化し、被害(Q2)・検知(Q3)・保全(Q4)・横展開(Q5)を配置すると全体像が一枚で見える。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「役割・段階・対象」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
攻撃モデル	キルチェーン：偵察～目的実行を直線的に順序づけた「線」のモデル	ATT&CK：順序を前提としない網羅的な手法辞書「面」(マトリクス)
TTP の階層	Tactics=目的(What)/Techniques=手段(How)：汎用的な手法分類	Procedures/IOC：特定攻撃者の具体実装や IP・ハッシュ等の個別指標
PtH の戦術	取得済みハッシュの再利用 = Lateral Movement/Defense Evasion	ハッシュをダンプする行為自体 = Credential Access(取り違え注意)
監視の範囲	EDR：エンドポイントの検知・対応/XDR：NW・クラウド・ID まで横断相関	SIEM = ログ収集・相関の製品/SOAR = 対応自動化(いずれも別概念)
バックアップ	イミュータブル+オフライン/エアギャップ+3-2-1で隔離保管	本番と同一 NAS に常時オンライン保存 = 暗号化が同時波及

TTP Tactics / Techniques / Procedures

Tactics=目的(What)、Techniques=手段(How)、Procedures=特定攻撃者の具体的実装。
1技法は複数戦術に属し得る。

 **MITRE ATT&CK****二重脅迫 Double Extortion**

暗号化に加えデータを窃取し、支払わなければ公開すると脅す手口。単なる「ランサムウェア」では不可。

 **ランサム最新動向****EDR / XDR / MDR**

EDR=端末の検知・対応、XDR=EDRをNW/クラウド/ID等へ拡張し横断相関、MDR=監視・運用を外部が代行。

 **検知・運用****Pass the Hash Pth**

NTLMハッシュ等をそのまま認証に再利用し、平文復元なしで横展開。ATT&CK では T1550.002。

 **T1550.002****IOC Indicator of Compromise**

IPアドレス・ファイルハッシュ等の侵害指標。Techniques より低抽象度で個別的。Techniques と混同しない。

 **侵害指標****イミュータブルバックアップ Immutable / WORM**

書き換え・削除ができない保存。3-2-1(3世代・2媒体・1拠点分離)+オフライン/エアギャップが定石。

 **3-2-1 ルール****揮発性の順序 Order of Volatility**

揮発性の高い順(CPUレジスタ/キャッシュ→メモリ→ディスクログ→媒体)に保全。電源断で消える情報を優先。

 **証拠保全の原則****Living off the Land LotL**

PowerShell 等の正規ツールを悪用する手法。シグネチャを回避するため振る舞い検知が有効。

 **正規ツール悪用**

④ 基礎概念 — フレームワーク・ツールマトリクス

「攻撃体系／防御体系／検知製品／可視化ツール」を混同しない

CONCEPT

名称	種別	要点（試験での問われ方）
MITRE ATT&CK	攻撃TTPの体系化(面)	実観測の攻撃者の振る舞いを戦術×技法で網羅。 Q1の題材 。順序を前提としないマトリクス。
サイバーキルチェーン	攻撃段階モデル(線)	偵察～目的実行を直線的な7段階で示す。ATT&CKとは相補的に併用(排他ではない)。
MITRE D3FEND	防御技術の体系化	対策側のマッピング 。攻撃TTPの体系化ではない=キルチェーン/ATT&CKとの取り違えに注意。
ATT&CK Navigator	可視化ツール	自社検知ルールがどの技術をカバーし空白があるかを可視化。午後問2の解。SIEM/SOARは不可。
EDR / XDR	検知・対応 製品	EDR=端末、XDR=横断相関。 Q3の題材 。振る舞い検知でLotL/未知亜種に対応。
MDR / SOC	監視・運用サービス	EDR/XDRの監視・運用を専門ベンダが24時間代行。SIEM(製品)・SOAR(自動化)とは別。

💡 **頻出の軸:** 「攻撃を体系化=ATT&CK/キルチェーン」 「防御を体系化=D3FEND」 「検知製品=EDR/XDR」 「運用代行=MDR」 「カバレッジ可視化=Navigator」。この取り違えが4択・午後のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. ATT&CK は **What=Tactics / How=Techniques / 実装=Procedures** の3階層。番号は Tactics=TA、Techniques=T。
2. 横展開の技法(PtH)は取得済みハッシュの「再利用」=Lateral Movement。ダンプ行為(Credential Access)と分ける。
3. ランサム対策はイミュータブル+オフライン(エアギャップ)+**3-2-1**が正解言葉。
4. フォレンジックは揮発性の高い順=メモリ→ディスク→媒体。ライブ(活性)採取を優先。

⚠ よくあるひっかけ

- EDR と XDR の説明を逆にする／SIEM(収集)・SOAR(自動化)をEDRと混同。
- バックアップを「本番と同一NASに常時オンライン」=同時暗号化で復旧不可。
- PtHで「平文パスワードを復元して」と書く選択肢=復元しないのが本質。
- 「単なるランサムウェア」で二重脅迫を答える／保全で先に電源を切る=揮発情報消失。

合言葉: 「攻撃は TTP で言語化」→ 対策は「**MFA**・イミュータブル/オフライン・横断相関(XDR)・振る舞い検知・ライブ保全」の5語彙に集約される。

MITRE ATT&CK(Enterprise)における Tactics、Techniques、Procedures(TTP)の関係の説明として、適切なものはどれか。

ア Procedures は攻撃者の最終目的を表す最上位の分類であり、その下位に Tactics と Techniques が位置づけられる

イ Tactics は達成しようとする目的(What)、Techniques はその手段(How)を表し、個々の攻撃者による具体的な実装が Procedures である

ウ Techniques は個別の攻撃で観測された IP アドレスやファイルハッシュなどの侵害指標(IOC)そのものを指す

エ Tactics は T 番号、Techniques は TA 番号で識別され、両者は 1 対 1 に対応する

正解 イ ア=階層が逆/ウ=IOCはProceduresより個別・低抽象度/エ=番号割当が逆かつ1対1でない

空 (事実)

Tactics=目的(What)、Techniques=手段(How)、Procedures=特定攻撃者の具体的実装、という3階層。

雨 (解釈)

識別子は Tactics=TA、Techniques=T(サブは T####.###)。1技法は複数戦術に属し得るため1対1ではない。

傘 (対策)

TTP を共通言語に脅威分析を行い、汎用手法(Techniques)と個別指標(IOC/Procedures)を分けて整理する。

ランサムウェアによる被害拡大を防ぐためのバックアップ運用として、最も効果が高いものはどれか。

ア バックアップデータを本番サーバと同一のファイルサーバ上の別フォルダに毎時保存する

イ 書き換え・削除ができないイミュータブル(改変不可)ストレージへ保存し、あわせてオフラインの複製を保持する

ウ バックアップ管理者と本番システム管理者に同一の特権アカウントを共有させ、復旧を迅速化する

エ ネットワーク上で常時オンラインの単一の共有ストレージに世代を集約し、容量効率を最優先する

正解 イ ア・エ=常時オンライン・同一系統で同時波及/ウ=特権共有で一括破壊リスク増

空 (事実)

近年のランサムウェアはバックアップの探索・破壊を定石とする。

雨 (解釈)

書き換え・削除不可のイミュータブル、3-2-1(3世代・2媒体・1拠点分離)、オフライン/エアギャップが有効。

傘 (対策)

イミュータブル/WORM保存+オフライン隔離複製。特権アカウントは分離し一括破壊を防ぐ。

実務メモ: 午後のランサム設問で頻出。「バックアップが本番と同一・オンライン・書き換え可能」だった点を復旧失敗の要因として特定できるかが分水嶺。

EDR、XDR、MDR の説明の組合せとして、適切なものはどれか。

ア EDR はネットワーク・クラウド・メール・ID まで横断的に相関分析する仕組みであり、XDR はエンドポイント単体に限定した監視である

ウ MDR はログを収集・相関する製品(SIEM)そのものを指し、EDR/XDR とは無関係である

イ XDR は EDR の監視範囲をエンドポイント外へ拡張し横断的に相関分析する仕組みであり、MDR はそれらの監視・運用を外部が代行するサービスである

エ EDR は対応を自動化するプレイブック実行基盤(SOAR)の別称であり、XDR はその上位互換である

正解 イ ア=EDRとXDRの説明が逆/ウ=SIEMは別概念/エ=SOARは別概念

空 (事実)

EDR=エンドポイントの監視・検知・対応、XDR=EDRを端末外へ拡張し横断相関。

雨 (解釈)

MDR=これらの監視・運用を専門ベンダが代行するサービス。SIEM(収集)・SOAR(自動化)とは別。

傘 (対策)

端末はEDR、横断相関はXDRで補い、自社に人的リソースが無ければMDRで24時間監視を委託。

インシデント対応におけるデジタルフォレンジックスで、揮発性の高い情報から順に証拠保全を行う原則(**Order of Volatility**)に従うとき、最も優先して取得すべきものはどれか。

ア ハードディスク上のログファイル

イ CPU レジスタ・キャッシュおよびメモリ上の情報

ウ 定期バックアップ用の磁気テープ

エ 監視カメラの録画データ

正解 イ 揮発性の高い順＝メモリ→ディスクログ(ア)→バックアップ媒体(ウ)→物理記録(エ)

▲ 空 (事実)

CPUレジスタ・キャッシュ・メモリ上の情報は電源断で失われる。

☂ 雨 (解釈)

メモリには実行中プロセス・NW接続状態・復号された暗号鍵が含まれ、最優先で保全すべき。

☂ 傘 (対策)

電源を切らず**活性(ライブ)状態**で揮発性情報から採取し、以降ディスク・媒体の順で保全する。

攻撃者が窃取済みの認証情報のハッシュ値を用い、平文パスワードを復元することなく他システムへ認証を通す横展開(Lateral Movement)の手法はどれか。

ア Pass the Hash

イ DNS リフレクション攻撃

ウ クリプトジャッキング

エ ディレクトリトラバーサル

正解 ア イ=DNS悪用のDRDoS/ウ=無断マイニング/エ=想定外ファイルへの不正アクセス

▲ 空 (事実)

NTLMハッシュ等をそのまま認証に再利用し、平文復元なしで他システムへ認証を通す。

☀ 雨 (解釈)

ATT&CK では T1550.002。ハッシュの再利用=Lateral Movement/Defense Evasion。ダンプ行為(Credential Access)と分ける。

☂ 傘 (対策)

LSASS保護・特権分離・NTLM制限・管理者ログオン制限、EDRでの認証情報アクセス検知。

👜 実務メモ: 取得済みハッシュの再利用が横展開/防御回避、ダンプ行為自体が Credential Access。この戦術の区別を問う選択肢が定番のひっかけ。



午後 記述式 — シナリオ要点

ランサムウェアIR / SOC 検知強化・フォレンジック

記述

◆ 問1 (秋想定) ランサムウェアIR

- 暗号化 + 窃取・暴露で金銭要求 → **二重脅迫(ダブルエクストーション)**。「ランサムウェア」だけでは不可。
- 侵入要因(認証観点) = **VPNにMFA未導入(単要素)** + パスワード使い回し(漏えい済み認証情報の悪用)。
- 復旧失敗 = バックアップが**本番と同一NAS**にオンライン・書換可で同時暗号化。改善 = イミュータブル + オフライン/3-2-1。
- ATT&CK戦術: LSASSダンプ = **Credential Access** / RDP他サーバ接続 = **Lateral Movement**。

◆ 問2 (春想定) SOC検知・フォレンジック

- 感染端末から外部C2へ自ら接続 → **コネクトバック通信**。境界FWは内→外を広く許可し正規通信に紛れ通過。
- 隔離後に電源を切らず**ライブ保全** = メモリ・NW接続・復号鍵は電源断で消失(Order of Volatility)。
- 正規プロセスからのPowerShell難読化実行 = **振る舞い(挙動)検知**。LotL型はシグネチャ回避のため連鎖を評価。
- 検知カバレッジと空白の可視化 = **ATT&CK Navigator**(SIEM/SOARは不可)。

採点の分水嶺: ①「**二重脅迫**」を明示 ②MFA未導入 + 使い回しの**両方** ③バックアップが同一・オンライン・書換可だった点 + イミュータブル/オフラインの二つ ④**Credential Access** と **Lateral Movement** を取り違えない ⑤Navigator を挙げられるか。



総合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度で攻撃・IR論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語集
MITRE ATT&CK / TTP・キルチェーン	最有力	中	What/How/実装
ランサムウェア / 二重脅迫・バックアップ	最有力	中	イミュータブル/3-2-1
EDR / XDR / MDR	最有力	低	横断相関/運用代行
フォレンジック / 揮発性の順序	高	中	メモリ優先/ライブ保全
横展開 / Pass the Hash・LotL	高	高	再利用=横展開/振る舞い検知

総括: 攻撃・IR分野は**午前IIの用語定義**(ATT&CK・EDR/XDR/MDR・PtH・揮発性順)と、**午後の実務シナリオ**(ランサムウェアIR・SOC検知)の両輪で狙われる。全論点を**ATT&CKの戦術**で言語化し、対策は「MFA・イミュータブル/オフライン・XDR横断相関・振る舞い検知・ライブ保全」に集約して固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

セキュリティマネジメント・法規

ISMS／リスク評価／個人情報保護法／サプライチェーン・SBOM。JIS Q 27000の用語定義から改正個人情報法、SBOM／SLSAまで、午前II・午後の双方で狙われる論点を5問で体系学習する。

Q1・JIS Q 27000

リスク対応の定義

頻出 ★★★

Q2・リスク管理

残留リスクの概念

頻出 ★★☆

Q3・改正個人情報法

漏えい報告の義務化

頻出 ★★★

Q4・SBOM

SPDX／CycloneDX

頻出 ★★★

Q5・サプライチェーン

SLSA と完全性確保

頻出 ★★☆

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「管理プロセス」→「法規制」→「サプライチェーン技術」で切り分ける学習動線

Q1

リスク対応

回避・低減・移転・保有の選択肢。特定/分析/評価(アセスメント)と対比する用語問題

JIS Q 27000 / 定義

Q2

残留リスク

対応後に残るリスク。受容にはリスクオーナーの承認。固有/二次リスク・選好と区別

リスク管理 / 承認

Q3

改正個人情報法

漏えい等報告・本人通知の義務化。要配慮個人情報・仮名加工情報・越境移転

個人情報法 / 2022施行

Q4

SBOM

構成部品表。
SPDX/CycloneDXで版数・依存を可視化し脆弱性影響を即特定

サプライチェーン / 部品表

Q5

完全性確保

SLSAで来歴保証、
cosign/Sigstoreで署名検証。typosquatting・推移的依存に注意

SLSA / 来歴

STEP 1 | WHY

ISMSのリスクマネジメント用語と法規制の全体像(なぜ管理・報告が要るか)を理解する

STEP 2 | HOW

5問で「どの用語・どの制度か」を判別し、似た概念のひっかけ選択肢を切る

STEP 3 | WHAT

空-雨-傘で対策(一元管理・SBOM整備・要配慮情報の同意・来歴検証)へ落とす

① 基礎概念 — 分野の全体像マップ

「マネジメント／法規制／サプライチェーン」の3層で本デッキ5問を配置

CONCEPT

層 / 領域	プロセス・仕組み	主なキーワード
リスクマネジメント	Q1 リスクアセスメント(特定・分析・評価)→リスク対応(回避/低減/移転/保有)	JIS Q 27000 / PDCA / リスク基準
リスクの状態	Q2 固有リスク→対応→ 残留リスク (リスクオーナー承認)	二次リスク / リスク選好 / 受容
法規制・コンプラ	Q3 改正個人情報保護法(2022全面施行)。漏えい報告・本人通知の義務化	要配慮個人情報 / 仮名加工情報 / 越境移転
サプライチェーン	Q4 SBOM(部品表) / Q5 SLSA・cosignによる完全性確保	SPDX / CycloneDX / 来歴 / 署名検証

核心: この分野は「①組織のリスクをどう回すか(ISMSプロセス・用語)」「②法令上どこまで義務か(個人情報法)」「③外部部品の弱点をどう管理するか(SBOM・SLSA)」の3層で切り分ける。用語の定義取り違えと、制度の適用範囲の勘違いが4択の失点源となる。

② 基礎概念 — 混同しやすい概念 比較表

似て見えるが「定義・タイミング・対象」が異なる5ペア

CONCEPT

対象概念	● 概念A	● 概念B (混同パターン)
プロセスの位置	リスク対応：リスクを 修正 するプロセス(回避・低減・移転・保有)	リスクアセスメント： 特定・分析・評価 の3工程。対応の前段
リスクの状態	残留リスク： 対応後 に残るリスク。受容はリスクオーナー承認	固有リスク： 管理策適用前 のリスク／二次リスク=対応策が生む新リスク
加工情報	要配慮個人情報：取得に原則 本人の事前同意 が必要。オプトアウト提供不可	仮名加工情報：原則 第三者提供禁止 (委託・承継・共同利用を除く)
SBOMフォーマット	SPDX：ISO/IEC 5962。ライセンス 管理 に強い	CycloneDX：OWASP発。 脆弱性・サプライチェーンセキュリティ に強い
サプライ攻撃	typosquatting：正規名に 酷似した名称 の悪意パッケージで誤インストール誘発	署名鍵・アカウント侵害：正規の 鍵/アカウント を窃取し改ざん版を公開

リスク対応 Risk Treatment

リスクを修正するプロセス。回避・除去・低減(起こりやすさ/結果の変更)・共有(移転)・保有(受容)の選択肢を選定・実施する。

 **JIS Q 27000:2019****要配慮個人情報**

人種・信条・病歴・健康情報等、不当な差別・偏見が生じ得る記述を含む個人情報。取得に原則本人の事前同意が必要。

 **個人情報保護法****SBOM 部品表**

ソフトウェアの構成部品(名称・版数・依存関係)を機械可読に一覧化。脆弱性公表時の影響範囲特定を迅速化。

 **SPDX / CycloneDX****cosign / Sigstore**

配布物・コンテナイメージ等への電子署名と検証を行う仕組み。成果物の真正性・完全性を担保する。

 **署名・検証****残留リスク Residual Risk**

リスク対応後になお残るリスク。その受容にはリスクオーナー(リスク所有者)の承認が必要。

 **リスク管理****仮名加工情報**

他情報と照合しない限り特定個人を識別できないよう加工した情報。原則、第三者提供は禁止。

 **個人情報保護法****SLSA**

Supply-chain Levels for Software Artifacts。ビルドの改ざん耐性・来歴(プロベナンス)の保証度合いをレベル化する枠組み。

 **サプライチェーン完全性****推移的依存 Transitive Dependency**

直接依存が更に依存する間接的な依存。脆弱性の影響評価では直接依存だけでなく推移的依存も対象とする。

 **依存関係管理**

④ 基礎概念 — 規格・フレームワーク／規制マトリクス

「用語規格／部品表／完全性FW／法令」を混同しない

CONCEPT

名称	種別	要点（試験での問われ方）
JIS Q 27000	用語規格(ISMS)	リスク特定/分析/評価/対応、残留リスク等の定義を規定。 Q1・Q2の根拠。
JIS Q 27001	ISMS要求事項	ISMS構築・運用・認証の要求事項。PDCAでリスクを継続管理。
個人情報保護法	国内法(2022全面施行)	漏えい等報告・本人通知の義務化、要配慮個人情報、仮名加工情報。 Q3の根拠。
SPDX / CycloneDX	SBOM標準フォーマット	SPDX=ISO/IEC 5962・ライセンス管理、CycloneDX=OWASP・脆弱性用途。 Q4。
SLSA	完全性フレームワーク	ビルド来歴の保証度合いをレベル化。改ざん耐性を段階的に要求。 Q5の正解。
NIST SSDF (SP800-218)	セキュア開発FW	開発ライフサイクル全体の実践事項。SBOM・来歴管理の上位文脈。

💡 頻出の軸: 「用語定義=JIS Q 27000」「ISMS認証=27001」「個人データの取扱い=個人情報」「部品可視化=SBOM(SPDY/CycloneDX)」「ビルド来歴保証=SLSA」。この対応の取り違えが4択のひっかけの定番。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. 用語問題は**プロセスの位置**で切る。対応=修正、アセスメント=特定/分析/評価。
2. 残留リスクは「**対応後**に残る+オーナー承認」がセット。固有/二次リスクと区別。
3. 個情法は**要配慮=取得に事前同意/仮名加工=第三者提供原則禁止**を丸暗記。
4. SBOMは「**版数・依存を可視化し影響範囲を即特定**」が主目的。SLSAは来歴保証。

⚠ よくあるひっかけ

- 漏えい報告は「人数によらず対象になる類型(要配慮・不正目的等)」がある。1,000人超だけではない。
- SBOMを「**動的監視(EDR)**」やバイナリのハッシュのみと説明する選択肢は誤り。
- typosquattingを「**署名鍵の窃取**」と説明するのは別攻撃との混同。
- 脆弱性評価で「直接依存だけ確認、推移的依存は不要」は誤り。

合言葉: 「定義(プロセスの位置)×制度(適用範囲)×技術(SBOM・来歴)」で分類 → 対策は「**一元管理・可視化・事前同意・来歴/署名検証・推移的依存まで評価**」の語彙に集約される。

JIS Q 27000:2019(情報セキュリティマネジメントシステム-用語)における「リスク対応」の説明として、適切なものはどれか。

ア リスクの重大性を評価するために、算定されたリスクを与えられたリスク基準と比較するプロセス

イ リスクを発見、認識及び記述するプロセスであり、リスク源、事象、それらの原因及び起こり得る結果の特定を含む

ウ リスクを修正するプロセスであり、リスクの回避、低減、共有(移転)及び保有(受容)などの選択肢を含む

エ リスクの特質を理解し、リスクレベルを決定するプロセス

正解 ウ ア=リスク評価/イ=リスク特定/エ=リスク分析(いずれもリスクアセスメントの構成要素)

▲ 空 (事実)

リスク対応(risk treatment)は「リスクを修正するプロセス」と定義される。

● 雨 (解釈)

回避・除去・低減・共有(移転)・保有(受容)の選択肢を選定・実施する段階。アセスメントの後工程。

✦ 傘 (対策)

用語は「特定→分析→評価(=アセスメント)」と「対応(=修正)」を明確に分けて暗記する。

組織が受容できないと判断したリスクについて、追加の管理策を導入した後になお残るリスクを表す用語はどれか。

ア 固有リスク

イ 残留リスク

ウ 二次リスク

エ リスク選好

正解 イ ア=管理策適用前のリスク/ウ=対応策自体が生む新リスク/エ=進んで受容・追求するリスクの量・種類

▲ 空 (事実)

残留リスク(residual risk)はリスク対応後に残るリスクを指す。

● 雨 (解釈)

受容にはリスク所有者(リスクオーナー)の承認が必要。「対応後」「承認」がセットの論点。

↑ 傘 (対策)

固有(前)/残留(後)の時間軸、二次リスク(新規発生)、リスク選好(量・種類)を4語で整理する。

📁 **実務メモ:** 残留リスクの受容判断はリスクオーナーが承認する点が午後でも問われやすい。「担当者が独断で受容」は誤り。

2022年4月に全面施行された改正個人情報保護法に関する記述のうち、適切なものはどれか。

ア 一定要件を満たす漏えい等が発生した場合、個人情報保護委員会への報告及び本人への通知が原則義務化された

イ 仮名加工情報は、他情報と照合しない限り個人を識別できない情報であり、第三者への自由な提供が認められている

ウ 外国の第三者へ個人データを提供する場合、本人同意があれば移転先国の制度に関する情報提供は不要である

エ 保有個人データの開示請求において、本人は書面交付のみを請求でき、電磁的記録による提供は求められない

正解 ア イ=仮名加工情報は原則第三者提供禁止/ウ=移転先国の制度等の情報提供が必要/エ=電磁的記録での提供も指定可

▲ 空 (事実)

改正法で漏えい等報告・本人通知が法的義務化された。

● 雨 (解釈)

対象は要配慮情報・財産的被害のおそれ・不正目的・1,000人超。前3類型は人数によらず対象。

↑ 傘 (対策)

漏えい検知時の報告フロー整備、越境移転時の情報提供、開示方法の電磁的対応を規程化する。

ソフトウェアの構成要素を一覧化する**SBOM**に関する記述のうち、適切なものはどれか。

ア **SPDX**と**CycloneDX**はいずれも**SBOM**の標準フォーマットで、**CycloneDX**は脆弱性やサプライチェーンのセキュリティ用途に強い

ウ **SBOM**を整備しても、Log4jのような脆弱性が公表された際に影響を受ける製品を特定する用途には利用できない

イ **SBOM**は実行時のメモリ上のプロセスを動的に監視し、不審な通信をリアルタイムで検知する仕組みである

エ **SBOM**は最終成果物のバイナリのハッシュ値のみを記録し、コンポーネントの名称・版数・依存関係は対象外である

正解 ア イ=EDR等の動的監視の説明で無関係/ウ=依存を辿り影響範囲を特定できる/エ=名称・版数・依存の記録が本旨

空 (事実)

SBOMは部品表。SPDX(ISO/IEC 5962・ライセンス管理)とCycloneDX(OWASP発・脆弱性用途)が代表。

雨 (解釈)

主利点は、脆弱性公表時に推移的依存まで辿り影響範囲を迅速に特定できること。

傘 (対策)

利用OSSの名称・版数・依存関係を機械可読なSBOMで一元管理し、継続的に更新する。

実務メモ: Log4Shellのような事案で「影響製品の特定に何日もかかる」課題への直接解が**SBOM整備**。午後の空欄補充で頻出。

ソフトウェアサプライチェーンの完全性を確保する取組みに関する記述のうち、適切なものはどれか。

ア SLSAは、ビルドプロセスの改ざん耐性・来歴(プロベナンス)の保証度合いをレベルで示すフレームワークである

ウ cosign(Sigstore)は、配布物への電子署名と検証を行うが、コンテナイメージには適用できない

イ typosquattingは、正規パッケージの署名鍵を窃取して同一名で改ざん版を公開する攻撃を指す

エ OSSの依存ライブラリに脆弱性が発見された場合、直接依存だけを確認すれば推移的依存の影響は考慮不要である

正解 ア イ=typosquattingは酷似名の悪意パッケージ(鍵窃取とは別)/ウ=cosignはコンテナイメージにも署名可/エ=推移的依存も評価対象

空 (事実)

SLSA(Supply-chain Levels for Software Artifacts)はビルド由来の保証度合いをレベル化する枠組み。

雨 (解釈)

来歴情報の生成・検証やビルド環境の改ざん耐性を段階的に要求する。完全性確保の共通尺度。

傘 (対策)

来歴の生成・検証、cosign/Sigstoreによる署名検証、推移的依存を含む脆弱性評価を組み合わせる。



午後 記述式 — シナリオ要点

D社(医療機器メーカー)/OSS利用とサプライチェーンリスクの管理

記述

◆ シナリオ (春想定) ログOSSの重大脆弱性

- 設問1: 影響特定に3日を要した根本原因 = 利用OSSの名称・版数を組織で一元管理する仕組みの欠如(管理体制の観点/40字)。
- 設問2: [a] = **SBOM**。効果 = 構成部品と版数が一覧化され、脆弱性公表時に影響製品を即座に特定できる(50字)。
- 設問3: [b] = **要配慮個人情報**(健康情報)。相違 = 取得時に原則本人の事前同意が必要。

◆ 再発防止・OSS受入れ基準

- 設問4(セキュリティ) = 既知の脆弱性・CVEの有無と対応状況を確認(30字)。
- 設問4(保守性) = 開発が継続され保守・更新が提供されているかを確認(30字)。
- 別解 = ライセンス適合性/配布元の署名・ハッシュによる真正性確認/コミュニティの活発さ。
- 全体 = 依存関係を継続管理するツール導入 + リスクアセスメント再実施(供給網型攻撃を踏まえ)。

採点の分水嶺: ①原因は「一元管理の欠如」という組織的原因(技術力不足などの外れ不可) ②SBOMの効果を下線①(特定に3日)と対応づけ ③要配慮個人情報の通常個人情報との相違(事前同意/オプトアウト不可、共通事項は不可) ④設問4はセキュリティと保守性の異なる2観点。



統合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でマネジメント・法規論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
リスク対応/アセスメント用語(27000)	最有力	低	プロセスの位置
残留リスク・リスクオーナー承認	高	中	対応後+承認
改正個人情報保護法(2022)	最有力	中	報告義務+要配慮
SBOM(SPDX/CycloneDX)	最有力	中	版数/依存の可視化
サプライチェーン完全性(SLSA/cosign)	高	高	来歴/署名検証

総括: この分野は午前IIの用語定義(リスク対応・残留リスク・要配慮/仮名加工)と、午後の実務シナリオ(OSS管理・SBOM整備・要配慮個人情報の取扱い)の両方で狙われる。近年最重要の**SBOM/サプライチェーン**と、必ず問われる**改正個人情報法の報告義務**を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。

SC EXAM PREP — PREDICTED 2026

AI駆動型サイバー攻撃・フロンティアAI

自律型攻撃/防御/デュアルユース/悪用リードタイム短縮/防御AIのHITLガバナンス。2026年のフロンティアAI登場で現実化した「攻撃と防御のAI化」を5問で体系学習する。

Q1・Governance

デュアルユースとフロンティアAIの公開制限

頻出 ★★★

Q2・Vuln Mgmt

悪用リードタイム短縮への対応

頻出 ★★★

Q3・Chaining

低スコア脆弱性の連鎖と攻撃経路

頻出 ★★☆

Q4・SOC AI

自律型防御エージェントとHITL

頻出 ★★★

Q5・Least Priv

防御AIエージェントへの権限付与原則

頻出 ★★☆

 基礎概念 5枚  問題演習 5問  統合サマリー  2026 春・秋 想定

※ 過去問傾向(令和3～7年)と最新動向をもとにAIが作成した予想問題です。実際の試験問題ではありません。最終確認を推奨します。



学習マップ — 5問の相互関係

MAP

「攻撃のAI化」→「守りの立て直し」→「防御のAI化ガバナンス」の学習動線

Q1

デュアルユース

脆弱性発見・悪用能力の高いAIは攻守両用。ゆえに提供を防御目的組織に限定

フロンティアAI統制



Q2

リードタイム

発見～悪用の自動化・高速化で公表～悪用の時間差が縮む
→パッチ運用見直し

リスクベース脆弱性管理



Q3

連鎖(チェーン)

低スコア脆弱性の組合せで権限昇格。CVSS閾値でなく攻撃経路で優先度

コンテキスト依存の優先度



Q4

SOC自律AI

検知～遮断を自律実行。誤検知で業務停止のリスク→高影響操作はHITL+監査

防御AIのガバナンス



Q5

最小権限

エージェントの誤動作・乗っ取り時の被害を限定。付与権限を必要最小限に

least privilege

STEP 1 | WHY

AIで「発見～悪用」が自動化・高速化し、攻守が同一能力で回るデュアルユース構造を理解する

STEP 2 | HOW

5問で「攻撃AI化への守り」と「防御AIのガバナンス」を判別し、ひっかけ選択肢を切る

STEP 3 | WHAT

空・雨・傘で対策(適用迅速化・攻撃経路優先・HITL・最小権限・監査)へ落とす

① 基礎概念 — 攻撃/防御のAI化 全体像

「攻撃ライフサイクル」×「攻撃側/防御側のAI化」の2軸で本デッキ5問を配置

CONCEPT

局面	攻撃側のAI化 (オフェンス)	防御側のAI化・ガバナンス (ディフェンス)
脆弱性の発見	脆弱性を自律的に発見(専門家を上回る能力)	Q1 デュアルユース→フロンティアAIの提供を防御目的組織に限定
悪用/武器化	Q2 実証コードを自動生成→公表～悪用のリードタイム短縮	リスクベースで適用サイクルを短縮(月次一括では間に合わない)
攻撃設計	Q3 低スコア脆弱性を連鎖(チェーン)し権限昇格	自社構成の攻撃経路・連鎖を踏まえ優先順位付け
検知～対応	攻撃の高速化・自動化で対応遅延が致命傷に	Q4 SOCで検知～遮断を自律実行 + Q5 最小権限・HITL・監査

核心: 脆弱性発見・悪用能力の高いAIは**防御(自組織の診断・修正)**にも**攻撃(第三者侵害)**にも使えるデュアルユース技術。攻撃のAI化は「①悪用リードタイム短縮」「②低スコア脆弱性の連鎖」で守りを崩し、防御のAI化は「③自律対応の高速化」と引き換えに「④誤検知・乗っ取りのガバナンス」を要求する。

② 基礎概念 — 混同しやすい概念 比較表

「正しい対応」と「もっともらしい誤答」を5ペアで対比

CONCEPT

対象概念	● 概念A (適切)	● 概念B (ひっかけ)
攻撃AI化の本質	公表～悪用のリードタイムが短縮し無防備期間が拡大	「試行頻度が下がる」「IPS更新を減らせる」など逆の効果と誤解
脆弱性の選別	攻撃経路・連鎖と資産の重要度でリスクベースに優先度付け	CVSS基本値が閾値以上のみ対応＝連鎖リスクを見落とす
フロンティアAI提供	デュアルユース性ゆえ防御目的組織に限定してアクセス許可	「推論コスト」「個人情報保護法」を本質理由と誤認
SOC自動化の範囲	影響大の対応は人間承認(HITL)を挟み判断根拠を記録	「AIは常に正確」と全自動実行＝誤検知で業務停止
エージェント権限	最小権限で乗っ取り・誤動作時の被害範囲を限定	迅速化のため管理者権限を常時付与＝被害拡大

フロンティアAI Frontier AI

脆弱性の自律的発見・攻撃コード生成などで人間の専門家を上回り得る高性能モデル。能力が一定水準を超えると悪用時の被害が甚大化する。

 高能力の最先端AI

悪用リードタイム Time-to-Exploit

脆弱性の公表から悪用開始までの期間。AIによる発見～悪用の自動化で短縮し、月次一括のバッチ運用では無防備期間が生じる。

 公表→悪用の時間差

リスクベース脆弱性管理 RBVM

CVSS基本値の閾値だけでなく、悪用可能性(露出)・資産の重要度・攻撃経路で対応の優先度を決める考え方。

 悪用可能性×重要度

最小権限の原則 Least Privilege

業務遂行に必要な最小限の権限のみ付与。エージェントの誤動作・乗っ取り時の被害範囲を限定する。

 被害範囲の限定

デュアルユース Dual-use

防御(診断・修正)にも攻撃(第三者侵害)にも使える両義性。武器化の恐れから提供先を防御目的組織に限定する運用の根拠となる。

 軍民・攻守両用性

脆弱性の連鎖 Vulnerability Chaining

単体ではCVSS基本値が低い複数脆弱性を組み合わせ、権限昇格など深刻な攻撃を成立させる手法。

 チェーン攻撃

human-in-the-loop HITL

影響の大きい/不可逆な対応(本番遮断・アカウント無効化等)の実行前に人間の承認を挟む統制。誤検知の業務停止を防ぐ。

 人間の承認組み込み

自律型AIエージェント Autonomous SOC Agent

SOARに加え、検知内容の分析・影響範囲調査・隔離/無効化までを自律実行。速度と引換えにガバナンスが要る。

 検知～対応の自律化

④ 基礎概念 — 規格・規制・優先度指標マトリクス

「AIガバナンス」と「脆弱性優先度」の道具を混同しない

CONCEPT

名称	種別	要点 (試験での問われ方)
NIST AI RMF	AIリスク管理FW	GOVERN/MAP/MEASURE/MANAGEでAIリスクを管理。攻撃TTP体系や認証規格ではない。
ISO/IEC 42001	認証規格(AIMS)	AIマネジメントシステムの認証規格。ISMS(27001)のAI版という位置づけ。
AI事業者ガイドライン	国内ガイドライン	総務省・経産省。開発者/提供者/利用者の3主体区分。組織統制・デュアルユース対応の根拠。
フロンティアAI安全性の枠組	提供者の自主的取組	危険能力の評価と、閾値超過時の提供制限等のリスク低減策。Q1の背景。
CISA KEV / EPSS	悪用可能性の指標	実際に悪用された脆弱性(KEV)・悪用確率(EPSS)。リードタイム短縮時代の優先度付けに有効。
CVSS 基本値	深刻度の指標	単体の深刻度。閾値のみでの選別は連鎖リスクを見落とす=Q3のひっかけ源。

💡 頻出の軸: 「AIリスク管理=AI RMF」「認証規格=42001」「国内統制=AI事業者ガイドライン」の3分類と、脆弱性優先度は「深刻度=CVSS」「悪用可能性=KEV/EPSS」「連鎖=攻撃経路」で切り分ける。CVSS一本での判断が4択・記述の定番ひっかけ。



試験のコツ & 頻出ひっかけ

Exam Strategy & Common Pitfalls

TIPS

✓ 解くコツ

1. 攻撃AI化の本質は「リードタイム短縮」と「連鎖による深刻化」。この2語で正解を選ぶ。
2. 優先度は悪用可能性(露出)×資産の重要度×攻撃経路。CVSS高い順「のみ」は誤答。
3. フロンティアAIの提供制限の理由はデュアルユース性。コスト・法令は本質理由でない。
4. 防御AIの自律化は「速度」と「HITL・最小権限・監査」をセットで語る。

⚠ よくあるひっかけ

- 「攻撃頻度が下がる」「IPS更新を減らせる」「IPブロックで十分」は逆・過小評価。
- 「AIは既知脆弱性しか悪用できない」→ゼロデイ発見にも使われ得るので誤り。
- 「低評価の脆弱性は恒久的に見送り」「全て一律同期限」は両極端で不適切。
- 「AIは常に人間より正確」「管理者権限を常時付与」「手順書は不要」はガバナンス放棄。

合言葉: 攻めは「リードタイム短縮×連鎖」、守りは「リスクベース優先度+HITL・最小権限・監査」。極端な断定(「常に」「全て」「不要」「十分」)の選択肢は**まず疑う**。

ソフトウェア脆弱性の自律的な発見と実証コード(エクスプロイト)生成において人間の専門家を上回る能力をもつAIモデルについて、開発元が一般公開やAPI提供を行わず、防御目的の組織に限定してアクセスを許可する運用を採ることがある。この判断の主な理由はどれか。

ア モデルの推論コストが高く、一般提供では採算が取れないため

イ 防御にも攻撃にも利用できるデュアルユース性を持ち、攻撃者の手に渡った場合に脆弱性の武器化が大規模かつ高速に行われるおそれがあるため

ウ 学習データに個人情報が含まれ、個人情報保護法の第三者提供制限に抵触するため

エ 生成する攻撃コードの品質が低く、誤検知を誘発して防御側の運用を妨げるため

正解 イ ア=採算/ウ=法令/エ=品質は、いずれも本質的な理由ではない

▲ 空 (事実)

脆弱性発見・悪用能力の高いAIは、自組織の診断・修正にも第三者への侵害にも使える。

● 雨 (解釈)

能力が一定水準を超えると悪用時の被害が甚大化する。ゆえに提供先を絞るのはリスク低減策。

✦ 傘 (対策)

危険能力の評価と閾値超過時のアクセス制限。防御目的組織に限定して提供する。

攻撃側がAIを活用して脆弱性の発見から悪用までを自動化・高速化する状況が、企業の脆弱性管理に与える影響として、最も適切なものはどれか。

ア 攻撃の試行頻度が下がるため、IPSのシグネチャ更新頻度を下げてよい

イ 脆弱性公表から悪用開始までのリードタイムが短縮するため、修正適用までの許容時間を見直し、悪用可能性に基づく優先順位付けと適用の迅速化が必要になる

ウ AIは既知の脆弱性しか悪用できないため、ゼロデイ攻撃への対策は不要になる

エ 攻撃が自動化されると攻撃元IPが固定されるため、IPアドレスブロックだけで十分な防御となる

正解 イ ア=更新は不要にならない/ウ=ゼロデイ発見にも用いられ得る/エ=IPブロックのみでは不十分

空 (事実)

AIによる自動化で、発見から悪用までの時間が大幅に短縮する。

雨 (解釈)

月次一括のような固定サイクルでは間に合わず、無防備な期間が生じる。

傘 (対策)

悪用可能性・資産の重要度によるリスクベースの優先順位付けと適用サイクルの短縮。

実務メモ: 午後の直球テーマ。「四半期一括適用」の危険性を「リードタイム短縮=無防備期間」で説明できるかが分水嶺。KEV/EPSSでの優先度付けと結び付けたい。

AIによる脆弱性分析では、単体ではCVSS基本値が低い複数の脆弱性を組み合わせて(チェーンして)権限昇格などの深刻な攻撃を成立させる能力が示されている。この状況を踏まえた脆弱性対応の考え方として、最も適切なものはどれか。

ア CVSS基本値が一定値以上の脆弱性のみを対応対象とすれば十分である

イ 低重要度の脆弱性は悪用されないので、対応を恒久的に見送ってよい

ウ 個々のスコアだけでなく、自社システムの構成における攻撃経路(複数脆弱性の連鎖を含む)を考慮して対応の優先順位を決める

エ すべての脆弱性に対して、重要度にかかわらず同一の期限で一律に対応する

正解 ウ ア・イ=閾値/軽視で連鎖を見落とす/エ=リソース有限で非現実的

▲ 空 (事実)

単体では低リスクに見える脆弱性でも、連鎖により深刻な侵害が成立し得る。

☂ 雨 (解釈)

CVSS基本値の閾値のみでの選別は連鎖リスクを見落とす。一方で一律対応も現実的でない。

☂ 傘 (対策)

自社固有の構成・攻撃シナリオ(攻撃経路)に基づき優先順位を決める。

SOCにおいて、検知から遮断までを自律的に実行するAIエージェントを導入する場合の留意点として、最も適切なものはどれか。

ア AIの判断は常に人間より正確なので、遮断の実行に人間の承認を挟む必要はない

イ 誤検知で正常業務が停止するリスクがあるため、影響の大きい対応(本番システムの遮断等)には人間の承認を組み込み、AIの判断根拠を記録・監査できるようにする

ウ AIエージェントには管理者権限を常時付与し、あらゆる対応を即時実行できるようにすべきである

エ AIエージェントを導入すれば、インシデント対応手順書や体制の整備は不要になる

正解 イ ア=承認省略は誤検知に無防備/ウ=常時管理者権限は被害拡大/エ=手順・体制は必要

空 (事実)

防御の自動化は対応の高速化に有効だが、誤検知時に正常業務を止めるリスクを伴う。

雨 (解釈)

影響度に応じてHITL(人間承認)を組み込むことが、防御AI運用のガバナンスの要点。

傘 (対策)

影響大の対応は人間承認 + 最小権限 + 判断根拠のログ記録・監査可能性を確保。

SOCに導入する自律型対応AIエージェントへ付与する権限について、誤動作や乗っ取り(注入指示等)が生じた場合の被害範囲を限定する観点から、最も適切な原則はどれか。

ア 対応の迅速化を最優先し、エージェントに管理者権限を常時付与する

イ 業務遂行に必要な最小限の権限のみを付与し、権限外の実行をできないようにする
(最小権限の原則)

ウ あらゆる操作を人手を介さず即時自動実行できるよう、権限の制限を撤廃する

エ 処理を高速化するため、判断根拠や操作履歴のログ記録を省略する

正解 イ ア=常時管理者権限は被害拡大/ウ=制限撤廃は逆効果/エ=監査可能性を損なう

▲ 空 (事実)

エージェントに与えた権限が過大だと、誤動作や乗っ取り時の被害が拡大する。

☂ 雨 (解釈)

最小権限は被害範囲を局所化する統制の基本。乗っ取り成立時も影響を限定できる。

☂ 傘 (対策)

業務に必要な最小権限のみ付与+権限分離。高影響操作はHITL、操作は監査ログ化。

📁 実務メモ: Q4(HITL・監査)と対で、防御AIガバナンスは「最小権限+人間承認+ログ」の3点セット。理由は必ず「誤動作・乗っ取り時の被害範囲の限定」で書く。



午後 記述式 — シナリオ要点

K社 脆弱性管理体制の見直し / S社 防御AIエージェント・ガバナンス

記述

◆ 問1 (春想定) K社 脆弱性管理体制の見直し

- 設問1 = 四半期一括が危険な理由: 悪用開始までのリードタイムが短縮し、次回適用まで無防備な期間が生じるから。
- 設問2 = 優先順位の観点2つ: ①悪用可能性(外部公開資産など露出) ②影響資産の事業上の重要度(脅威情報も可)。
- 設問3 = 低CVSSも対応要の理由: AIが複数の低評価脆弱性を連鎖させ権限昇格など深刻な攻撃を成立させ得るから。

◆ 問2 (秋想定) S社 SOC 防御AIエージェント

- 設問1 = 完全自動化のリスク: 誤検知による自動遮断で正常業務(勘定系)が停止するおそれ。
- 設問2 = 設計方針: 影響が限定的な対応は自動実行、本番遮断など影響大は人間承認(HITL)を経て実行。
- 設問3 = 権限原則: 最小権限。理由 = 誤動作・乗っ取り時の被害範囲を限定するため。
- 設問4 = 記録事項: ①判断根拠(検知内容・入力情報) ②実行した対応内容と時刻(承認者含む操作履歴も可)。

採点の分水嶺: ①「リードタイム短縮=無防備期間」を結び付ける ②優先度は「露出×重要度」の2軸(CVSS高い順のみは不十分) ③低評価も「連鎖(チェーン)」で深刻化 ④防御AIは「影響度に応じたHITL+最小権限+判断根拠・実行内容のログ(監査可能性)」まで踏み込んでいるか。



総合サマリー — 頻出ヒートマップ & 総括

出題可能性 × 難易度でAI駆動型攻撃・フロンティアAI論点を俯瞰

SUMMARY

論点	出題可能性	難易度	対策語彙
デュアルユース／フロンティアAI提供制限	最有力	低	攻守両用・提供限定
悪用リードタイム短縮／脆弱性管理	最有力	中	リスクベース優先度
脆弱性の連鎖／攻撃経路	高	中	攻撃経路で優先度
SOC自律防御AI／HITL	最有力	高	影響度×人間承認
防御AIエージェントの最小権限・監査	高	中	最小権限+ログ

総括: 本分野は午前IIの用語・構造理解(デュアルユース／リードタイム短縮／連鎖／HITL)と、午後の実務シナリオ(脆弱性管理体制の見直し／SOCの防御AIガバナンス)の両輪で狙われる。攻めは「リードタイム短縮×連鎖」、守りは「リスクベース優先度+HITL・最小権限・監査」に集約。極端な断定選択肢を切る力を最優先で固めること。

※本デッキはAIが過去問傾向・最新動向をもとに作成した予想問題です。正解・解説・図解は最終確認を推奨します。ペンダー・製品名は本試験には登場しません。